

AWS SECURITY SERVICES

A Deep Technical Reference Guide

Mapped to the NIST Cybersecurity Framework (CSF) 2.0

Govern • Identify • Protect • Detect • Respond • Recover

*Architecture patterns, configuration depth, and real-world implementation guidance
for multi-account, multi-cloud, multi-tenant SaaS environments*

Table of Contents

Table of Contents	2
Purpose & Framework Note	5
How to use this document	5
Why this structure, for a multi-cloud multi-tenant SaaS platform specifically	5
1. GOVERN	6
1.1 AWS Organizations	6
Mechanism	6
Policy Types	6
Real-World SCP Patterns	6
Alternatives / Complements	7
1.2 AWS Control Tower	8
Mechanism	8
Limitations	8
Alternatives	9
1.3 AWS Config (Governance Lens)	9
Conformance Packs	9
Aggregators	9
Alternatives	10
1.4 IAM Access Analyzer — Policy Generation & Governance	10
1.5 AWS Artifact	11
1.6 Govern Function — Summary Table	12
2. IDENTIFY	13
2.1 AWS Security Hub	13
Mechanism	13
Where it falls short	14
Alternatives / Complements	14
2.2 Amazon Inspector	14
Mechanism	14
Alternatives	15
2.3 Amazon Macie	15
Mechanism	15
Limitations and alternatives	16
2.4 Trusted Advisor & Resource Explorer	16
Alternatives	17
2.5 IAM Access Analyzer — External Access Findings	17
2.6 Identify Function — Summary Table	18

3. PROTECT	20
3.1 AWS Identity and Access Management (IAM)	20
Core Mechanism	20
IAM Identity Center (formerly AWS SSO)	20
ABAC for Multi-Tenant Isolation	20
Where it falls short / common failure modes	21
Alternatives / Complements	21
3.2 AWS Key Management Service (KMS)	21
Mechanism	22
CMEK (Customer-Managed Encryption Keys) for Multi-Tenant Isolation	22
Alternatives	23
3.3 Secrets Manager vs. Systems Manager Parameter Store	23
3.4 AWS WAF	24
Mechanism	24
Limitations and alternatives	25
3.5 AWS Shield (Standard & Advanced)	25
3.6 AWS Network Firewall	26
3.7 Security Groups, NACLs & VPC Architecture	27
3.8 AWS Certificate Manager (ACM)	28
3.9 Amazon Cognito	29
Mechanism relevant to multi-tenant SaaS	29
3.10 AWS CloudHSM	30
3.11 S3 Security Controls	30
3.12 AWS Systems Manager — Session Manager & Patch Manager	32
3.16 Protect Function — Summary Table (Part 1)	32
3.13 Amazon CloudFront	33
Mechanism	33
Where it falls short / limitations	34
Alternatives	35
3.14 Amazon Route 53	35
Mechanism	35
Alternatives	36
3.15 AWS Firewall Manager	36
Mechanism	36
Where it falls short	37
Alternatives	38
4. DETECT	39
4.1 Amazon GuardDuty	39

Detection mechanism.....	39
Limitations and alternatives	40
4.2 Security Hub — Detection Aggregation & Correlation	40
4.3 AWS CloudTrail	40
Event types and what they actually capture	40
Alternatives / complements	41
4.4 Amazon CloudWatch — Security Use	42
4.5 Amazon Detective	42
4.6 VPC Flow Logs	43
4.7 Macie & Config — Detection Angle	44
4.8 Detect Function — Summary Table	44
5. RESPOND	46
5.1 Amazon EventBridge	46
5.2 AWS Lambda — Automated Remediation	47
5.3 AWS Systems Manager Incident Manager	48
5.4 AWS Step Functions — Response Orchestration.....	48
5.5 WAF & Network Firewall — Active Response.....	49
5.6 The Multi-Source Detection & Remediation Pipeline Pattern	50
5.7 Respond Function — Summary Table	50
6. RECOVER.....	51
6.1 AWS Backup.....	51
Mechanism	51
Alternatives	52
6.2 S3 Versioning & Object Lock — Recovery Angle.....	52
6.3 AWS Elastic Disaster Recovery (DRS).....	53
6.4 Config & CloudFormation — Recovery Angle.....	53
6.5 Multi-Account Recovery Pattern — Summary	54
6.6 Recover Function — Summary Table	55
Appendix A — Full Service Cross-Reference Matrix	56
Appendix B — Architecture Principles Referenced Throughout	57

Purpose & Framework Note

This document is a deep technical reference for AWS security services, organized around the NIST Cybersecurity Framework (CSF) 2.0's six functions — Govern, Identify, Protect, Detect, Respond, Recover — rather than AWS's own service categories. It is written for security architects, cloud security engineers, and detection engineering teams operating a multi-account, multi-cloud SaaS environment, and assumes familiarity with core AWS concepts (accounts, IAM, VPCs) rather than re-explaining them from first principles.

A note on terminology: CSF vs. RMF

NIST publishes two related but distinct frameworks that are frequently conflated. The NIST Risk Management Framework (RMF, SP 800-37) is a structured, document-heavy process for federal information systems — Categorize, Select, Implement, Assess, Authorize, Monitor — built around formal Authorization to Operate (ATO). The NIST Cybersecurity Framework (CSF 2.0) is the outcome-based, six-function model — Govern, Identify, Protect, Detect, Respond, Recover — that most commercial and SaaS organizations actually use to structure a security program, because it maps cleanly to capability areas rather than a compliance authorization workflow. This document uses CSF's six functions as the organizing structure, since that is what the requested Govern/Detect/Protect/Respond/Recover breakdown corresponds to, and because it is the framework genuinely in active use for commercial cloud security architecture rather than RMF's federal ATO process.

How to use this document

- Each service entry covers: what it actually does mechanically (not the marketing description), the specific configuration knobs that matter in practice, where it's the right tool versus where it falls short, and the AWS-native or third-party alternatives worth knowing about.
- Every service includes a set of three real-world implementation scenarios — one each for Banking/Financial Services, SaaS/Multi-Tenant Platform, and E-Commerce — grounded in the kind of specific architectural decision, trade-off, or near-miss that actually comes up in practice for that industry, rather than a generic restatement of the feature.
- Several services appear in more than one function section, deliberately — AWS Config, Security Hub, Macie, and IAM Access Analyzer each have genuinely distinct mechanical roles depending on which function lens you're viewing them through, and force-fitting each service into exactly one function would misrepresent how they're actually used.
- Each major section closes with a summary table for quick reference; the full cross-reference matrix is in the appendix.

Why this structure, for a multi-cloud multi-tenant SaaS platform specifically

The CSF functions map directly onto the recurring architecture review questions for a SaaS platform operating across AWS, Azure, and GCP while serving multiple tenants from shared infrastructure: Govern answers "who decided this is how we run AWS, and how do we know every account actually follows it." Identify answers "what do we actually have, and where does sensitive multi-tenant data actually live." Protect answers "what stops tenant A from ever touching tenant B's data, and what stops an external attacker regardless." Detect and Respond answer "how fast do we know something's wrong, and how fast do we act on it, across every cloud and tool we run, not just AWS." Recover answers the question most often skipped in architecture reviews: "if our primary defenses fail anyway, what's the actual floor."

1. GOVERN

The Govern function establishes the organizational structure, account topology, policy-as-code guardrails, and audit posture that every other function depends on. In a multi-account AWS estate, Govern is not a checklist — it is the set of structural decisions (account vesting, SCP boundaries, delegated administration) that determines whether Protect, Detect, and Respond controls can even be enforced consistently. Get Govern wrong and every downstream control becomes an exception-management exercise.

1.1 AWS Organizations

AWS Organizations is the root-level control plane for a multi-account AWS estate. It is not optional infrastructure for any company beyond a single team running a single workload — it is the mechanism by which account-level blast radius is contained, billing is consolidated, and policy is inherited down an OU hierarchy rather than configured per account.

Mechanism

Organizations structures accounts into a tree: a management (root) account, Organizational Units (OUs) that group accounts by function or environment, and member accounts. Policies attach at any level of the tree and are inherited downward — an SCP on the root applies to every account in the org; an SCP on a "Production" OU applies only to accounts inside it. The management account itself should run no workloads — its only job is org-level governance, consolidated billing, and break-glass access. This is the single most violated principle in real-world AWS estates: teams provision workloads directly in the management account because it's the first account that existed, and years later it's too entangled to migrate.

Policy Types

Service Control Policies (SCPs)	Maximum permission boundaries. SCPs do not grant permissions — they define the ceiling of what IAM policies inside member accounts can ever grant, even to the account root user. An SCP denying <code>ec2:RunInstances</code> outside approved regions cannot be overridden by any IAM policy, admin role, or root credential inside that account.
Resource Control Policies (RCPs)	Newer policy type (2024) that constrains resource-based policies (S3 bucket policies, KMS key policies, etc.) org-wide — closing the gap SCPs always had, since SCPs only govern the principal side, not the resource side. RCPs let you enforce, for example, that no S3 bucket policy in the org can grant access to a principal outside the org, regardless of what an individual bucket owner configures.
Tag Policies	Enforce consistent tagging schemas (cost-center, data-classification, environment) across accounts — operationally this is what makes RBVM and ASPM risk-scoring actually work, because asset criticality tagging has to be consistent for risk-based prioritization to mean anything.
Backup Policies	Org-wide enforcement of AWS Backup plans — assign backup plans centrally rather than trusting each account team to configure their own.
AI Services Opt-Out Policies	Org-wide control over whether AWS AI services can use account data for model improvement — relevant for any org handling regulated or customer data.

Real-World SCP Patterns

In practice, SCP strategy follows a maturity curve. Early-stage orgs write deny-list SCPs (block specific dangerous actions: leaving the org, disabling CloudTrail, deleting GuardDuty detectors). Mature orgs invert this to allow-

list/region-lock patterns combined with deny-list guardrails for high-risk actions that should never be allowed regardless of role:

- Deny all actions outside approved regions, with an exception for global services (IAM, CloudFront, Route 53) — written as a condition on `aws:RequestedRegion`.
- Deny disabling or modifying CloudTrail, GuardDuty, Config, and Security Hub from within member accounts — these should only be manageable from the security-tooling/audit account via delegated administration.
- Deny root user actions entirely except through a tightly controlled break-glass process — root sessions should generate a real-time alert.
- Deny creation of IAM users in workload accounts — force IAM Identity Center federation so there are no long-lived account-local credentials to leak.
- Deny public S3 bucket policy attachment org-wide as a backstop even though S3 Block Public Access exists at the account level — defense in depth against someone disabling BPA.

Where it falls short

SCPs are coarse and account-wide; they cannot do resource-level conditional logic the way an IAM policy can, and a poorly written SCP can lock an entire OU out of a service with no warning until someone hits the deny. Always test new SCPs in a sandbox OU before attaching to production OUs, and keep a documented break-glass path that bypasses the management account's own SCP restrictions in case of a true lockout.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Regulatory data-residency enforcement across OUs

A core banking platform operates separate OUs for retail banking (subject to local data-residency law requiring all processing to stay within the country's AWS regions) and a global card-processing subsidiary. An SCP attached to the retail banking OU denies any API call where `aws:RequestedRegion` is outside the two approved in-country regions, with no exception even for IAM admin roles — including a hard deny on cross-region S3 replication APIs specifically, since a well-meaning engineer enabling cross-region replication for DR purposes would otherwise create an unauthorized cross-border data copy without anyone noticing until the next regulatory exam.

SAAS / MULTI-TENANT PLATFORM

Preventing tenant data from ever leaving the shared production boundary

A multi-tenant SaaS platform structures its OUs by environment (Sandbox, Dev, Staging, Production) rather than by team, specifically so a single Production OU-level SCP can deny S3 cross-account replication, deny attaching any IAM policy granting `s3:PutObject` to a principal outside the org, and deny creating new KMS key grants to external accounts — closing off the most common accidental-exfiltration path where a developer wires up a one-off data export to a personal or vendor AWS account for a POC and forgets to remove it.

E-COMMERCE

Blast-radius containment during peak sales events

An e-commerce retailer running a Black Friday-scale traffic event locks down its Production OU with a temporary, time-boxed SCP (applied via a change-managed pipeline, not manually) that denies all IAM, security group, and network ACL modification APIs across the entire OU for the duration of the event window — eliminating the risk of an unrelated, routine change (a misconfigured deploy, a forgotten firewall rule edit) destabilizing the platform during the only week of the year when downtime has the highest revenue impact.

Alternatives / Complements

There is no real alternative to Organizations for AWS-native multi-account governance — it is the foundation everything else (Control Tower, Security Hub delegated admin, GuardDuty org-wide enablement) is built on. The

meaningful alternative decision is whether to hand-roll the OU/SCP structure or use Control Tower to scaffold it (see 1.2). For policy-as-code outside AWS's own constructs, HashiCorp Sentinel or Open Policy Agent (OPA) are sometimes layered on top for cross-cloud consistency, but they operate at the CI/CD or Terraform-plan stage, not as a runtime enforcement boundary the way SCPs are.

1.2 AWS Control Tower

Control Tower is an opinionated automation layer on top of Organizations, Config, and CloudTrail that scaffolds a multi-account landing zone: it provisions the standard OU structure (Security, Sandbox, etc.), sets up a Log Archive account and an Audit account, deploys baseline SCPs, and enforces "guardrails" — pre-built detective and preventive controls mapped to common compliance frameworks.

Mechanism

Control Tower's core unit is the guardrail. Preventive guardrails are implemented as SCPs and block disallowed actions outright (e.g., disallow public read access to S3). Detective guardrails are implemented as Config rules and flag non-compliant resources after the fact, surfaced in the Control Tower dashboard. Mandatory guardrails (around CloudTrail, Config) cannot be disabled; strongly recommended and elective guardrails can be turned on by OU.

Account Factory, the second core component, standardizes new account creation — every new account is vended with the same baseline (CloudTrail enabled, Config recording on, VPC defaults removed, SSO access configured) instead of someone manually clicking through account setup and forgetting a step. Account Factory for Terraform (AFT) extends this so account provisioning is itself a Terraform-managed pipeline, which is the pattern most platform teams converge on once they're past a handful of accounts.

Where it's best used

Control Tower earns its keep at the point an org has more than roughly 10-15 accounts and a platform/cloud team responsible for account vending. Below that scale, the operational overhead of learning Control Tower's opinions and working around its constraints (it is genuinely opinionated about OU naming, account email conventions, and update sequencing) can exceed the value versus hand-rolling Organizations + a Terraform module.

Limitations

- Control Tower updates are not always backward compatible with heavily customized landing zones — orgs that deviate significantly from its defaults (custom OU structures, third-party SIEM as log destination) end up managing drift between what Control Tower expects and what's actually deployed.
- It does not replace a CSPM — its detective guardrails are a useful baseline but far shallower than what Security Hub, Wiz, or Prisma Cloud provide for posture management.
- Multi-cloud orgs (the common case for SaaS companies also running Azure/GCP) get no equivalent cross-cloud view from Control Tower — it is AWS-only by design.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Standardized account vesting for new regulated business lines

When a bank launches a new regulated product line (e.g., a new lending subsidiary), Account Factory vends a new account pre-baked with PCI-DSS and SOC 2 conformance packs already attached via Control Tower's guardrail framework, the standard Transit Gateway attachment to the existing hub-spoke network already wired in, and CloudTrail/Config/GuardDuty already enabled — cutting the time from business approval to a compliant, audit-ready AWS account from the weeks manual setup used to take down to under a day, which matters when the regulatory approval timeline is itself the long pole.

SAAS / MULTI-TENANT PLATFORM**Per-environment guardrail tiers for a fast-growing engineering org**

A SaaS company with 40+ engineering teams uses Control Tower's OU-based guardrail tiering so every team's Dev/Sandbox accounts get a lighter guardrail set (allowing broader experimentation, fewer SCP restrictions) while every Production account — regardless of which team owns it — automatically inherits the strict Production OU guardrails the moment Account Factory promotes it, removing the recurring failure mode where a team's production account quietly never got the same hardening their sandbox account started with.

E-COMMERCE**Seasonal account provisioning for marketing microsites**

An e-commerce brand spins up short-lived, isolated AWS accounts for seasonal campaign microsites (a holiday gift guide, a flash-sale landing page) using Account Factory for Terraform so each microsite account is born with the same security baseline as core production — including mandatory WAF attachment and GuardDuty — despite being a marketing-owned, throwaway account, closing the gap where marketing-built infrastructure has historically been the most under-governed corner of the AWS estate precisely because it's treated as temporary.

Alternatives

Hand-rolled Organizations + Terraform (modules like terraform-aws-modules/account or custom internal modules) gives full control at the cost of building and maintaining the guardrail logic yourself. For multi-cloud landing zones, some orgs use Terraform/Terragrunt as the common provisioning layer across AWS, Azure, and GCP precisely so the account/subscription/project vending logic isn't locked into one cloud's opinionated tooling.

1.3 AWS Config (Governance Lens)

Config records resource configuration state and changes over time and evaluates that state against rules. It surfaces under both Govern and Identify in this document because its function is genuinely dual: it is how policy is operationalized into continuous compliance evidence (Govern) and how configuration drift and misconfigured assets are surfaced (Identify). The governance angle is covered here; the detection mechanics are covered in Section 3.2.

Conformance Packs

A Conformance Pack is a collection of Config rules and remediation actions packaged against a compliance framework — AWS publishes ready-made packs for CIS AWS Foundations Benchmark, PCI-DSS, NIST 800-53, HIPAA, and others. Deploying a conformance pack org-wide via Control Tower or StackSets gives you a continuously evaluated compliance posture instead of a point-in-time audit — the difference between passing a SOC 2 audit in March and knowing your compliance posture right now.

In practice, the value of conformance packs is less about the canned ones and more about building custom conformance packs that encode the company's actual internal security standard (derived from the CSA CCM, in many SaaS orgs) as Config rules — so determining whether you're compliant with your own architecture standard becomes a query, not a quarterly spreadsheet exercise.

Aggregators

A Config Aggregator collects configuration and compliance data from multiple accounts and regions into a single account (typically the Audit/Security Tooling account), which is what makes org-wide compliance dashboards possible without querying every account individually. This is the same underlying mechanism Security Hub and many third-party CSPMs rely on for AWS-native data collection.

Real-World Implementation Scenarios**BANKING / FINANCIAL SERVICES**

Continuous PCI-DSS evidence for card-data environments

A bank's card-processing environment runs the AWS-published PCI-DSS conformance pack across every account in the cardholder-data-environment OU, with results aggregated into the Audit account and exported nightly into the bank's GRC platform — converting what was previously a quarter-end scramble to manually evidence PCI controls into a continuously available compliance posture that the QSA can query directly during the annual assessment, cutting weeks off the audit cycle.

SAAS / MULTI-TENANT PLATFORM**Custom conformance pack encoding the company's own tenant-isolation standard**

A SaaS platform writes a custom Config conformance pack encoding its own internal architecture standard — every S3 bucket tagged data-classification:tenant-data must have a bucket policy condition restricting access to aws:sourceVpce, every RDS instance serving production tenant data must have a specific parameter group enforcing row-level security extensions enabled — turning the question of whether a service follows the multi-tenancy architecture standard from a manual architecture-review exercise into an automatically evaluated, dashboarded answer across hundreds of microservice-owning accounts.

E-COMMERCE**Drift detection on payment-page infrastructure ahead of PCI scans**

An e-commerce retailer runs a dedicated Config rule set against the checkout/payment subsystem specifically, set to evaluate continuously rather than on the default periodic schedule, so that a security group accidentally opened during a hotfix deploy to the payment service is flagged and auto-ticketed within minutes — well before the quarterly external ASV scan would have caught it, which matters because a finding caught internally never becomes a finding the QSA or a customer's security team discovers independently.

Alternatives

Config rules and conformance packs are AWS-native and free of additional licensing (you pay per configuration item recorded and per rule evaluation, which adds up at scale but is rarely the binding constraint). Third-party CSPM/CNAPP platforms like Wiz and Prisma Cloud largely supersede Config's compliance-rule function for cross-cloud organizations — they ingest the same underlying API data but present unified findings across AWS, Azure, and GCP, with materially better risk contextualization (attack path analysis, exploitability scoring) than Config rules alone provide. Most mature multi-cloud orgs keep Config running for the audit trail and as the data source for custom Lambda-based auto-remediation, while using Wiz/Prisma as the actual posture management interface analysts work from day to day.

1.4 IAM Access Analyzer — Policy Generation & Governance

Access Analyzer has two distinct capabilities that get conflated. The external-access-finding capability (covered in Identify, Section 3.6) tells you what's currently exposed. The policy generation and validation capability — relevant here — is what makes least-privilege IAM actually achievable at scale rather than an aspirational principle nobody has time to implement.

- **Policy generation:** Access Analyzer can observe a role's or user's actual CloudTrail activity over a lookback period and generate an IAM policy containing exactly the permissions used — turning the task of auditing and tightening an overly broad role from a multi-day manual log review into a generated draft policy a human reviews and approves.
- **Policy validation:** Runs over 100 policy checks (overly permissive wildcards, unused principals, syntax errors) at policy-authoring time via IAM console, CLI, or CI/CD pipeline integration — catching wildcard-action mistakes before they're deployed rather than after a posture scan flags them in production.
- **Custom policy checks:** Lets you assert specific properties a policy must never have (for example, that a policy must never grant full S3 access on the production data bucket) and run that assertion in CI as a hard gate — this is the building block for embedding IAM guardrails directly into the deployment pipeline rather than relying purely on SCPs as a runtime backstop.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Tightening a legacy batch-processing role inherited from a migration

A bank migrating an overnight settlement batch job from on-prem to AWS inherited an IAM role with broad S3 and DynamoDB wildcard permissions, written under deadline pressure during the lift-and-shift. Six months post-migration, Access Analyzer's policy generation feature is run against 90 days of the role's actual CloudTrail activity, producing a draft policy scoped to exactly the eleven specific S3 prefixes and four DynamoDB tables the job actually touches — reviewed by the security architecture team and rolled out as the new least-privilege policy, closing a wildcard-permission finding that had been sitting on the risk register since the migration.

SAAS / MULTI-TENANT PLATFORM

CI-gated custom policy check preventing cross-tenant IAM grants

A SaaS platform's Terraform CI pipeline runs an Access Analyzer custom policy check on every pull request that modifies an IAM policy, asserting that no policy may grant read or query access on a resource ARN pattern matching another team's tenant-data prefix — turning what used to be a manual architecture-review checklist item into an automated, merge-blocking CI gate that catches an over-broadly-scoped role before it ever reaches a review meeting.

E-COMMERCE

Quarterly least-privilege review of the recommendation-engine service role

An e-commerce company's product recommendation service started with a broadly-scoped IAM role to move fast during initial development. As part of a quarterly access review, the security team runs Access Analyzer policy generation against the role and discovers it no longer needs write access to the order-history table it was originally prototyped against — that dependency was removed in a refactor eight months earlier but the IAM policy was never updated, a textbook example of the privilege-creep gap policy generation is built to close.

Real-world value

The policy generation feature is consistently underused. Most teams write IAM policies broad on day one and never circle back. Wiring Access Analyzer's generated-policy output into a quarterly access review — even a manual one where a security engineer reviews the diff between current policy and generated least-privilege policy per role — closes a huge fraction of the privilege-creep gap without needing a third-party entitlement management tool.

1.5 AWS Artifact

Artifact is AWS's self-service portal for compliance documentation — SOC 1/2/3 reports, PCI attestations, ISO certifications, and the AWS side of shared-responsibility evidence auditors ask for. Its only real function is evidentiary: when a customer security questionnaire or an internal audit asks for proof of AWS's infrastructure controls, Artifact is the source, not something you configure.

Artifact Agreements additionally lets you accept and track required legal agreements (BAA for HIPAA, certain regional data processing addenda) at the account or org level, which matters operationally because some AWS services are gated behind having an active agreement in place for that account.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Responding to a regulator's infrastructure-control inquiry

During a regulatory examination, a bank's compliance team is asked to demonstrate the physical and infrastructure-level security controls of its cloud provider. Rather than waiting on an AWS account manager,

the team pulls the relevant SOC 2 Type II report directly from Artifact within the exam window, with the report's coverage period and scope already matching what the examiner needs — because this retrieval path was pre-validated during the bank's own cloud-adoption risk assessment, not discovered for the first time mid-exam.

SAAS / MULTI-TENANT PLATFORM

Closing enterprise customer security questionnaires faster

A SaaS company's sales engineering team fields a security questionnaire from a prospective enterprise customer asking for evidence of the cloud provider's compliance posture as part of vendor due diligence. The relevant ISO 27001 certificate and SOC 2 report are pulled from Artifact and attached directly to the questionnaire response within the same day, rather than the multi-day delay that used to occur waiting on a manual AWS support request — shortening the sales cycle on deals where security review is the long pole.

E-COMMERCE

Maintaining an active data-processing agreement for health-adjacent purchase data

An e-commerce platform that sells over-the-counter health products and processes data falling under HIPAA-adjacent handling requirements for that product line uses Artifact Agreements to track and maintain the relevant data-processing agreement at the account level for the subset of accounts handling that product line specifically — keeping the agreement scoped narrowly rather than applying stricter handling requirements across the entire e-commerce platform unnecessarily.

This service has no real alternative or competing pattern — it's the canonical source for AWS-side compliance evidence regardless of what CSPM or GRC tooling sits on top.

1.6 Govern Function — Summary Table

Service	Primary Role	Pairs With
AWS Organizations	Account structure, SCPs/RCPs, policy inheritance	Control Tower, IAM Identity Center
Control Tower	Landing zone automation, account vending	Organizations, Account Factory for Terraform
AWS Config	Continuous compliance evaluation, conformance packs	Security Hub, Wiz/Prisma Cloud
IAM Access Analyzer	Least-privilege policy generation & validation	CI/CD pipelines, IAM Identity Center
AWS Artifact	Compliance evidence repository	GRC platforms, audit workflows

2. IDENTIFY

Identify is the function most teams underinvest in relative to its leverage: you cannot protect, detect against, or assess risk on an asset, identity, or dataset you don't know exists. In a multi-tenant SaaS environment running across multiple clouds, asset and data inventory drift is constant — new services spin up via IaC pipelines faster than any manual inventory process can track, and shadow IT in the form of forgotten S3 buckets or unmanaged IAM roles from a six-month-old POC is the norm, not the exception.

2.1 AWS Security Hub

Security Hub is AWS's native aggregation layer for security findings — it does not generate most findings itself; it ingests them from GuardDuty, Inspector, Macie, Config, IAM Access Analyzer, and a long list of third-party integrations (Tenable, Wiz, Prisma Cloud, Qualys, CrowdStrike) and normalizes them into the AWS Security Finding Format (ASFF).

Mechanism

- **Security standards:** Security Hub ships automated checks against CIS AWS Foundations Benchmark, AWS Foundational Security Best Practices (FSBP), PCI-DSS, and NIST 800-53 — each check maps to a Config rule under the hood and produces a pass/fail finding with a severity and remediation link.
- **Cross-account/cross-region aggregation:** a designated administrator account (typically the Audit account) can view and act on findings across the entire organization without switching roles into every member account — this is the delegated administration pattern that makes Security Hub usable at scale.
- **Insights:** saved, reusable queries across the finding corpus (e.g., all critical findings on internet-facing EC2 instances in production accounts) — the practical unit analysts work from rather than scrolling the raw finding feed.
- **Security Hub CSPM** (the newer, GA'd unified posture experience) adds exposure and attack-path context on top of raw findings — closer to what Wiz/Prisma provide natively, narrowing the historical gap between Security Hub and dedicated CNAPP tooling.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Unified PCI-DSS posture view across card-issuing and core-banking subsidiaries

A bank with separate card-issuing and core-banking subsidiaries, each running their own AWS sub-organization, delegates Security Hub administration to a single group-wide security operations account so the CISO's team gets one aggregated PCI-DSS compliance score across both business lines instead of two disconnected dashboards — and a Security Hub Insight saved specifically for any critical finding tagged against a cardholder-data-environment account routes directly into the bank's existing GRC ticketing workflow.

SAAS / MULTI-TENANT PLATFORM

Correlating findings across hundreds of microservice-owning accounts

A SaaS platform running 200+ AWS accounts (one per microservice team, under a service-per-account model) uses Security Hub's cross-account aggregation so the central platform security team sees every FSBP and Inspector finding across the entire fleet in one console, with custom Insights filtering specifically for findings on any account tagged tier:customer-facing — letting a four-person central security team maintain visibility a team that size could never achieve logging into 200 separate consoles.

E-COMMERCE

Pre-event posture sweep ahead of a major promotional sale

An e-commerce company runs a Security Hub Insight query a week before a major promotional event filtering for any critical or high finding on resources tagged service:checkout or service:inventory, specifically to clear

the backlog of medium-priority findings that accumulate the rest of the year on the systems that will see the highest transaction volume and highest attacker interest during the sale window.

Where it falls short

- Cross-cloud correlation is genuinely weak — Security Hub has no native concept of an Azure VM or a GCP service account, so in a true multi-cloud estate it becomes one of several posture sources rather than the single source of truth.
- Attack-path and exposure graph analysis, while improved, is still less mature than Wiz's graph-based approach, which correlates identity, network exposure, and vulnerability data into a single exploitability path without needing the analyst to pivot between tools.
- Alert fatigue is a real operational risk — out of the box, FSBP and CIS checks generate a high volume of low-severity findings that need suppression rules or a downstream ASPM/RBVM layer (ArmorCode in this architecture) to make triage tractable.

Alternatives / Complements

Wiz and Prisma Cloud are the two dominant CNAPP alternatives for organizations needing real multi-cloud CSPM with stronger risk graphing; both can ingest from and feed into Security Hub rather than fully replacing it. For pure aggregation and correlation without AWS lock-in, a SIEM (Splunk, Sentinel, Chronicle) fed directly by CloudTrail/VPC Flow Logs/GuardDuty findings is the path orgs take when Security Hub's normalization format is too AWS-specific for their detection engineering needs.

2.2 Amazon Inspector

Inspector is AWS's native vulnerability management service for EC2, container images (ECR), and Lambda functions. It replaced the legacy Inspector Classic with a continuous, agentless (for most workloads) scanning model.

Mechanism

EC2 scanning	Uses the SSM Agent (already required for Systems Manager) to continuously assess installed software against the National Vulnerability Database (NVD) — no separate agent deployment needed if SSM is already managed, which it should be.
ECR scanning	Scans container images on push and continuously re-scans stored images as new CVEs are published against their package manifests — this re-scan-on-new-CVE behavior is the detail that matters: an image scanned clean six months ago can silently become vulnerable as new CVEs are disclosed, and Inspector catches that without a new push triggering it.
Lambda scanning	Scans function code and dependencies for known vulnerabilities at deployment and on a recurring basis — relevant because Lambda functions are frequently excluded from server vulnerability management scope entirely in less mature programs.
Network reachability	Correlates vulnerability findings with actual network exposure (security groups, NACLs, route tables) to produce a reachability score — a critical vulnerability on an instance with no path from the internet is scored very differently than the same CVE on an internet-facing instance, which is the single biggest lever for cutting false urgency in vuln reports.

Risk score	Combines CVSS, exploit intelligence (CISA KEV, EPSS-like signals), and network reachability into a single Inspector risk score per finding — this is what should feed an RBVM platform's prioritization logic rather than raw CVSS.
-------------------	---

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Prioritizing patch cycles for internet-facing online-banking gateways

A bank's vulnerability management team uses Inspector's network reachability scoring to separate critical CVEs found on the internal mainframe-integration layer (no route from the internet, lower urgency despite a high raw CVSS) from the same CVE found on the customer-facing online-banking API gateway (directly internet-reachable) — ensuring the gateway patch goes through an expedited, off-cycle change window while the internal finding follows the standard monthly patch cadence, instead of treating both as equally urgent based on CVSS alone.

SAAS / MULTI-TENANT PLATFORM

Catching a re-emerged CVE in a container image that hadn't been rebuilt in months

A SaaS platform's billing microservice runs a container image that was scanned clean at build time and hadn't been rebuilt since, since the service was stable. Inspector's continuous ECR re-scanning flags a newly disclosed critical CVE in a base-image OpenSSL package six weeks after the image was last pushed — triggering an automated Jira ticket via the EventBridge-to-ArmorCode pipeline before any external scanner or customer disclosure surfaced it, despite no code change having happened on the team's side at all.

E-COMMERCE

Lambda dependency scanning on the checkout pricing-calculation function

An e-commerce platform's checkout flow calls a Lambda function performing tax and discount calculation, built on a third-party pricing-rules library. Inspector's Lambda scanning flags a known-vulnerable transitive dependency in that library during a routine scan — caught specifically because Lambda functions were brought into vulnerability management scope explicitly, after an earlier internal audit found Lambda had been excluded from the vulnerability program's reach entirely.

Real-world implementation note

The highest-leverage Inspector configuration most teams skip is enabling it org-wide via the delegated administrator pattern and exporting findings continuously to the RBVM/ASPM platform (ArmorCode, in this architecture) rather than triaging inside the Inspector console. Inspector is a strong scanner; it is a weak triage and remediation-tracking interface, and trying to run a VM program entirely inside the AWS console at any scale beyond a handful of accounts becomes unmanageable.

Alternatives

Tenable Nessus/Tenable.io and Qualys remain common where the organization needs a single vulnerability management tool spanning on-prem, AWS, Azure, and GCP with one licensing model and one risk-scoring methodology — exactly the rationale for running Tenable alongside Inspector rather than relying on Inspector alone in a multi-cloud estate. Snyk and Wiz both also do container and IaC vulnerability scanning with a stronger developer-workflow (shift-left, PR-comment) integration than Inspector natively offers.

2.3 Amazon Macie

Macie is a data security service purpose-built for S3: it uses machine learning and pattern matching to discover and classify sensitive data (PII, PHI, financial data, credentials) across an S3 estate, and separately evaluates bucket-level security posture (encryption, public access, sharing).

Mechanism

- Sensitive data discovery jobs: scheduled or one-time jobs that sample or fully scan objects in specified buckets, using built-in managed data identifiers (SSNs, credit card numbers, AWS keys, common PII patterns) plus custom data identifiers you define with regex for organization-specific sensitive data formats (internal customer ID formats, proprietary record numbers).
- Automated sensitive data discovery: a lighter-weight, continuous, sampling-based mode that maintains an up-to-date sensitivity map across the entire S3 estate without the cost of full jobs on every bucket — the practical default for ongoing coverage, with targeted full jobs reserved for buckets flagged as high-risk.
- Bucket-level findings: independent of content scanning, Macie flags buckets with public access, missing encryption, or sharing outside the account/org — overlapping with what Config and Security Hub also catch, but Macie's view is specifically data-risk-weighted.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Catching account-number patterns in a misconfigured analytics export bucket

A bank's data analytics team exports anonymized transaction data nightly into an S3 bucket for a fraud-modeling pipeline. A custom Macie data identifier configured to match the bank's specific 16-digit internal account number format (distinct from standard credit card patterns) flags that the anonymization step had a bug stripping customer names but not account numbers — caught within a day of the bug being introduced rather than being discovered months later during a data-handling audit.

SAAS / MULTI-TENANT PLATFORM

Detecting PII in a support-ticket attachment bucket nobody classified as sensitive

A SaaS company's customer support tool automatically archives ticket attachments (screenshots, log file uploads from customers troubleshooting issues) into an S3 bucket that was never tagged or treated as a sensitive-data store, since it wasn't part of the core product's data model. Macie's automated continuous discovery flags that a meaningful percentage of archived attachments contain customer PII (screenshots showing account emails, occasionally pasted API keys) — prompting a retroactive encryption and access-control upgrade on a bucket that had effectively fallen outside the data classification program entirely.

E-COMMERCE

Flagging a public bucket holding scanned ID images from a returns-fraud process

An e-commerce retailer's returns-fraud-prevention team occasionally requests a photo ID for high-value return disputes, stored in S3. Macie's bucket-level findings flag that the bucket holding these images was inadvertently left with public-read accessible via a previous bucket policy that predates the BPA rollout, while content scanning simultaneously confirms the bucket contains a high concentration of personally identifying images — combining the two signals into a single high-severity, immediately actionable finding rather than two disconnected lower-priority ones.

Limitations and alternatives

Macie is S3-only — it has no native equivalent for RDS, DynamoDB, or data sitting in Snowflake/BigQuery, which is a real gap for SaaS companies whose primary customer data lives in a relational or warehouse layer rather than object storage. Third-party data security posture management (DSPM) tools (Wiz's DSPM module, BigID, Varonis) extend classification across databases, SaaS apps, and multiple clouds, and are the natural next step once Macie's S3-only scope becomes the limiting factor.

2.4 Trusted Advisor & Resource Explorer

These two are grouped because they answer the same underlying question from different angles: what do we actually have, and is any of it obviously wrong.

- **Trusted Advisor (Security category):** checks for a defined set of common misconfigurations — open security groups on high-risk ports, IAM password policy weaknesses, MFA on root, exposed access keys, S3

bucket permissions. The Business and Enterprise support tiers unlock the full security check set and programmatic API access; without a paid support plan, the security checks available are minimal. This is frequently the gap that surprises smaller orgs — Trusted Advisor's value is almost entirely gated behind support tier.

- **Resource Explorer:** a unified, near-real-time search index across all resources in all enabled regions of an account (and across an org with multi-account search), queryable by resource type, tag, or free text. Its security relevance is purely as an inventory tool — when an incident response or audit needs to find every resource matching a given pattern without manually checking every service console in every region, Resource Explorer is the fast path.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Sweeping for exposed access keys after a contractor offboarding gap

After discovering a third-party contractor's offboarding process had a gap that left an IAM access key active for two weeks past contract end, the bank's security team uses Trusted Advisor's exposed-access-key check (enterprise support tier) combined with a Resource Explorer query across every account for any IAM user created in the relevant date range — confirming no other contractor accounts shared the same offboarding gap before closing the incident.

SAAS / MULTI-TENANT PLATFORM

Finding every resource tagged to a deprecated internal project during a cost and security cleanup

A SaaS platform's cloud team uses Resource Explorer's multi-account, multi-region search to find every resource tagged project:legacy-billing-v1 across the entire 200-account estate ahead of decommissioning that system — surfacing several forgotten EC2 instances and an open security group in a region nobody on the current team realized the old system had ever been deployed to, which would otherwise have remained running and unmonitored indefinitely.

E-COMMERCE

Baseline security-group hygiene check ahead of a PCI ASV scan

An e-commerce company on AWS Business support runs Trusted Advisor's security group check ahead of its quarterly external PCI ASV scan specifically to catch any security group with unrestricted inbound access on a sensitive port that a developer opened temporarily for debugging and forgot to close — closing the finding internally rather than having it surface as a failed control on the formal scan report sent to the acquiring bank.

Alternatives

AWS Config's advanced query and the Config aggregator provide a more structured, historically-queryable inventory than Resource Explorer's point-in-time search, at the cost of needing Config enabled and recording (which most security-mature accounts already have). Third-party CSPM tools again subsume much of this — Wiz and Prisma Cloud both maintain a continuously updated resource graph across clouds that functions as inventory plus posture in one view, which is generally a better experience than stitching together Resource Explorer, Config, and Trusted Advisor by hand.

2.5 IAM Access Analyzer — External Access Findings

This is the other half of Access Analyzer (the policy-generation half is covered in Govern, Section 1.4). Using automated reasoning (a formal logic/Zelkova-based analysis, not heuristics or sampling), Access Analyzer evaluates every resource policy that supports cross-account access — S3 buckets, IAM roles, KMS keys, Lambda functions, SQS queues, Secrets Manager secrets — and produces a finding for every path by which a principal outside a defined zone of trust (the account, or the entire organization) can access that resource.

The automated reasoning detail matters operationally: this is not a scan that might miss an edge case in policy logic the way a regex-based or sampling-based check could. It is a mathematically exhaustive analysis of the

policy's actual effect, which is why it is trusted as an authoritative answer on actual exposure rather than one more noisy alert to verify.

- **Unused access analysis:** a related but distinct Access Analyzer capability that flags IAM roles, permissions, and access that have gone unused for a configurable period — the other side of the least-privilege problem, surfacing over-provisioned access even when nothing is externally exposed.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Catching an overly broad KMS key policy left from a vendor integration

A bank integrating with a third-party fraud-detection vendor granted that vendor's AWS account decrypt access on a KMS key during a proof-of-concept, intending to scope it down before production. Access Analyzer's external access finding on that key policy persists as an open finding for months, eventually escalated through a governance review specifically because Access Analyzer findings on KMS keys protecting regulated data are treated as a standing, non-suppressible finding category rather than something that ages out of attention.

SAAS / MULTI-TENANT PLATFORM

Detecting a tenant-data S3 bucket policy with an overly broad cross-account principal

A SaaS platform's data-export feature, allowing enterprise customers to receive their data via an S3 bucket policy granting their AWS account read access, had one specific bucket policy written with a principal block too broad due to a copy-paste error during initial implementation — Access Analyzer's exhaustive policy analysis flags the actual effective access as broader than intended, caught and corrected before any other customer's account could have exploited the misconfiguration to access another tenant's export bucket.

E-COMMERCE

Identifying unused admin-level access following an M&A integration

Following an acquisition, an e-commerce company integrated the acquired company's AWS accounts into its own organization. Access Analyzer's unused access analysis run six months later identifies that several broad administrative roles carried over from the acquired company's original setup have had zero actual API activity since the integration — surfacing a clear least-privilege cleanup list without needing months of manual cross-team interviews about which legacy roles are still actually needed.

Real-world implementation note

Wiring Access Analyzer findings into the same Tines/EventBridge pipeline used for GuardDuty is one of the highest-signal, lowest-noise integrations available — an external access finding on a production data resource is almost never a false positive worth deprioritizing, unlike many CSPM misconfiguration findings that need business context to triage correctly.

2.6 Identify Function — Summary Table

Service	Primary Role	Pairs With
Security Hub	Finding aggregation, posture standards	GuardDuty, Inspector, Wiz/Prisma, Tines
Inspector	Host/container/Lambda vulnerability scanning	ECR, SSM, ArmorCode, Tenable
Macie	S3 sensitive data discovery & classification	KMS, S3 BPA, DSPM tools

Service	Primary Role	Pairs With
Trusted Advisor	Baseline misconfiguration checks (support-tier gated)	Security Hub, Config
Resource Explorer	Cross-region/account resource search	Config aggregator, IR workflows
Access Analyzer (external access)	Exhaustive cross-account exposure analysis	EventBridge, Tines, SOAR

3. PROTECT

Protect is the largest function by service count because it spans identity, data, and network — the three control domains where a multi-tenant SaaS platform carries the most risk of cross-tenant compromise. The organizing principle worth stating up front: in a multi-tenant architecture, every Protect control should be evaluated not just on whether it stops an external attacker but on whether it stops tenant A from ever touching tenant B's data or compute, because that second failure mode is the one that ends companies.

3.1 AWS Identity and Access Management (IAM)

IAM is the control plane for who and what can do anything in AWS. Treating it as a solved problem after initial setup is the most common and most consequential mistake in cloud security programs — IAM is never static; it accumulates privilege over time as a default failure mode unless actively governed.

Core Mechanism

- Policy evaluation logic: an explicit Deny anywhere (identity policy, resource policy, SCP, permission boundary, session policy) always wins. Absent an explicit deny, an action is allowed only if some policy explicitly allows it — default is deny. The practical implication: a single misplaced explicit Deny in a policy hundreds of lines long can silently break access in ways that are painful to debug, which is why IAM Policy Simulator and Access Analyzer's policy validation should be standard pre-deployment steps, not post-incident debugging tools.
- Permission boundaries: a distinct construct from SCPs — a permission boundary is attached to a specific IAM role or user and caps what that identity can be granted, even by its own identity policies. The standard use case is delegated admin: letting an application team create their own IAM roles for their workloads, with a permission boundary ensuring none of those self-created roles can ever exceed a defined ceiling.
- Roles vs. users vs. resource-based policies: long-lived IAM users with static access keys should be close to zero in a mature environment. Every human authenticates via IAM Identity Center (federated, temporary credentials); every workload assumes a role via STS (instance profiles, IRSA for EKS, Lambda execution roles) or uses resource-based policies where the resource itself defines who can access it — important because resource-based policies allow cross-account access without the accessing account needing to assume a role at all, which is both powerful and a common source of unintended exposure.

IAM Identity Center (formerly AWS SSO)

Identity Center is AWS's native workforce identity broker — it federates with an external IdP (Okta, Entra ID, etc.) via SAML/SCIM and issues short-lived, role-based access to AWS accounts without ever creating IAM users. Permission sets (the Identity Center construct, which compile down to IAM roles in each target account) are assigned to groups synced from the external IdP via SCIM, so access provisioning and deprovisioning flows from the IdP's group membership rather than being managed natively in AWS at all.

ABAC for Multi-Tenant Isolation

Attribute-based access control — using session tags (passed at STS AssumeRole time, often derived from a JWT claim like a `tenant_id`) referenced in IAM policy conditions (matching `aws:PrincipalTag/tenant_id` against a resource tag) — is the standard pattern for scaling tenant isolation without creating a unique IAM role per tenant, which becomes unmanageable past a small number of tenants.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Permission boundaries for a self-service developer platform inside a regulated bank

A bank's internal developer platform team lets application squads create their own IAM roles via a self-service Terraform module, but every role created through that module automatically gets a permission boundary

attached capping it to the squad's own designated S3 prefix and DynamoDB table namespace — meaning even if a squad writes an overly permissive IAM policy for their own role, the permission boundary prevents that role from ever touching another squad's ledger data or the core-banking account, regardless of the mistake.

SAAS / MULTI-TENANT PLATFORM

ABAC session tags enforcing tenant isolation in a shared compute pool

A multi-tenant SaaS platform running shared, horizontally-scaled application servers passes a `tenant_id` session tag at STS AssumeRole time, derived from the validated JWT claim on the incoming request, and IAM policies on the data-access role condition on `aws:PrincipalTag/tenant_id` matching a tag on the target S3 prefix and DynamoDB partition key — so a request that somehow had its application-layer authorization bypassed would still be denied at the IAM layer before ever reaching another tenant's data, providing a genuine second independent control rather than relying on application logic alone.

E-COMMERCE

Resource-based policy review after a third-party fulfillment integration

An e-commerce company integrating with a third-party fulfillment provider initially granted that provider's AWS account access to an order-data S3 bucket via a resource-based bucket policy, since the provider needed access without assuming a role in the retailer's account. A subsequent IAM review specifically audits every resource-based policy in the account (the class of permission that doesn't show up in a typical identity-policy-focused review) and discovers the fulfillment provider's access, originally scoped to a 90-day pilot, had never been time-boxed or revisited two years later.

Real-world implementation note

The single highest-leverage IAM hardening step most orgs still haven't done: eliminating long-lived IAM user access keys entirely for human access, and tracking the remaining count as a governance KPI on the executive security dashboard. A near-zero count of IAM users with active access keys is a far more meaningful metric than most posture scores, because static credentials are disproportionately represented in real-world breach root causes.

Where it falls short / common failure modes

- Wildcard resource ARNs paired with broad actions remain endemic in hand-written policies, especially ones generated early in a service's life and never revisited.
- Cross-account trust policies with overly broad principal blocks combined with a weak or missing condition are a recurring finding in third-party access reviews and the exact pattern Access Analyzer's external access findings are designed to catch.
- IAM has no native concept of tenant-scoped data access — multi-tenant data isolation has to be engineered at the application/data layer because IAM alone cannot express tenant boundaries that don't map to AWS account or resource boundaries.

Alternatives / Complements

There is no real alternative to IAM as AWS's own control plane. The meaningful alternatives are in the entitlement management layer: CIEM tools (Wiz's CIEM module, Prisma Cloud's CIEM) provide cross-cloud entitlement visibility, unused-permission analysis, and toxic-combination detection at a level of cross-cloud correlation native IAM tooling cannot reach on its own, since it's AWS-scoped by definition.

3.2 AWS Key Management Service (KMS)

KMS is the encryption key management backbone for nearly every AWS data service — S3, EBS, RDS, DynamoDB, Secrets Manager, and dozens more all integrate with KMS for envelope encryption rather than implementing their own key management.

Mechanism

Envelope encryption	KMS rarely encrypts data directly. It generates and protects data keys; the actual bulk data encryption happens client-side using a data key that KMS issued and that is itself encrypted by the KMS Customer Master Key (CMK) — meaning the CMK's plaintext key material never leaves the KMS HSM boundary.
Key types	AWS-owned keys (no visibility/control), AWS-managed keys (visible, but rotation and policy are AWS-controlled, free), and customer-managed keys (CMKs) — full control over key policy, rotation, and grants, the only option where compliance requires customer control over key lifecycle.
Key policies vs. IAM policies	Every KMS key has a resource-based key policy evaluated alongside IAM policy — by default a CMK's key policy must explicitly allow IAM policies to govern access; without it, IAM policies alone never grant access to that key regardless of how permissive they look.
Grants	A more temporary, programmatic alternative to modifying key policy — used heavily by AWS services themselves and useful for short-lived cross-account or cross-service access patterns without permanent key policy changes.
Automatic key rotation	For symmetric CMKs, AWS can rotate the backing key material annually while preserving the same key ID and all existing grants/policies — old key material is retained internally to decrypt data encrypted under it previously.
Multi-Region keys	Replicate a CMK (same key material) across regions so encrypted data can be decrypted in a DR region without re-encrypting.

CMEK (Customer-Managed Encryption Keys) for Multi-Tenant Isolation

For SaaS platforms handling sensitive multi-tenant data, the key architecture decision with the most downstream consequence is per-tenant vs. shared CMKs (sometimes referred to as customer-managed encryption keys, or CMEK, when the tenant or customer is given visibility or control over their own key). A shared CMK across all tenants is operationally simpler but means a single compromised application identity with decrypt permission can technically read any tenant's data once it has the ciphertext. Per-tenant CMKs mean a compromised path to one tenant's decrypt permission cannot be used against another tenant's data even if the application layer's authorization logic fails, because the IAM/key policy boundary is the second independent control.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Per-subsidary CMKs enforcing legal-entity data separation

A bank with multiple legal-entity subsidiaries sharing common AWS infrastructure uses a dedicated KMS CMK per legal entity for all customer data encryption, with key policies restricting decrypt permission to only that entity's application roles — so a regulatory requirement that one subsidiary's customer data must never be accessible to another subsidiary's systems, even under shared infrastructure, is enforced cryptographically rather than relying solely on application-layer access control that a future code change could inadvertently break.

SAAS / MULTI-TENANT PLATFORM

Per-tenant CMEK for API keys stored in Secrets Manager, scoped via IAM

A B2B SaaS platform storing customer-supplied third-party API keys (a customer's own Stripe key, their own Slack webhook token) uses Secrets Manager for storage, with each secret encrypted under a per-tenant KMS CMK rather than the account default key. The application's secret-retrieval Lambda assumes a tenant-scoped IAM role (via the ABAC session-tag pattern from Section 3.1) that only has kms:Decrypt permission on that specific tenant's CMK — meaning even if the secret-retrieval code had a bug allowing it to query another

tenant's secret ID, the decrypt call would fail at the KMS layer because the assumed role's key policy grant doesn't cover that tenant's key, giving a hard cryptographic backstop to a logic-layer mistake rather than relying on the application getting tenant-scoping right every time.

E-COMMERCE

Dedicated CMK for payment-tokenization data separate from general application data

An e-commerce platform uses a KMS CMK dedicated exclusively to encrypting tokenized payment references (not raw card data, which never touches their environment under their PCI SAQ scope) separate from the CMK used for general customer profile data — so the much smaller set of engineers and services with a legitimate need to touch payment-token data can be granted decrypt access narrowly on that one key, while the broader application team's standard data-access roles have no path to it at all, shrinking the PCI-relevant access review scope to a small, explicit list instead of the entire engineering org.

Alternatives

CloudHSM (Section 3.10) is the alternative when compliance mandates dedicated, single-tenant HSM hardware rather than KMS's multi-tenant HSM fleet. External key management (KMS External Key Store, XKS) lets you keep key material in an external HSM or key manager you control while still using KMS's API surface and AWS service integrations.

3.3 Secrets Manager vs. Systems Manager Parameter Store

These two are constantly conflated and the choice between them is asked in nearly every cloud architecture review, so the distinction is worth being precise about.

Capability	Secrets Manager	Parameter Store (SecureString)
Automatic rotation	Native, with built-in Lambda rotation templates for RDS, Redshift, DocumentDB and a framework for custom rotation Lambdas	None natively — rotation must be built and orchestrated entirely externally
Pricing model	Per-secret monthly charge plus API call charges	Free for standard parameters; Advanced tier has a small per-parameter charge
Cross-account sharing	Native resource policies for cross-account access	Possible but less commonly used this way; typically single-account scoped
Versioning	Built-in version staging (current/previous labels) designed for rotation workflows	Basic version history, not designed around rotation staging
Best fit	Database credentials, API keys, anything needing automated rotation or cross-account access	Application configuration values, feature flags, secrets where rotation is handled by another mechanism

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Automated rotation of a core-banking database credential with zero-downtime cutover

A bank's core-banking application uses Secrets Manager's native RDS rotation template to rotate the database master credential every 30 days automatically, with the rotation Lambda performing a dual-credential cutover (creating the new credential, validating connectivity, then retiring the old one) so the rotation happens with no application downtime and no manual coordination with the on-call team — replacing a previous quarterly manual rotation process that required a maintenance window.

SAAS / MULTI-TENANT PLATFORM**Storing tenant-supplied third-party API keys, encrypted with per-tenant CMEK**

Directly extending the KMS scenario above: a multi-tenant SaaS platform's integrations feature lets each customer supply their own third-party API keys (their own Salesforce token, their own payment-gateway key) for the platform to use on their behalf. Each tenant's collection of supplied keys is stored as a Secrets Manager secret encrypted under that tenant's dedicated KMS CMK, with a tenant-scoped IAM role (via ABAC session tags) as the only principal with both the Secrets Manager read permission and the corresponding KMS decrypt grant — so the secret is doubly tenant-isolated, by IAM policy on the secret itself and by KMS key policy on its encryption key, and an application-layer authorization bug in either control alone is not sufficient to expose one tenant's third-party credentials to another tenant's request context.

E-COMMERCE**Parameter Store for feature flags and pricing-engine configuration**

An e-commerce platform's pricing engine reads several hundred configuration values (promotional thresholds, regional tax rate table references, feature flags for A/B-tested checkout flows) from Parameter Store rather than Secrets Manager, since none of these values are credentials needing rotation — keeping the high-volume, frequently-read configuration data in the free tier rather than incurring Secrets Manager's per-secret charge across hundreds of non-secret configuration values, while reserving Secrets Manager specifically for the much smaller number of actual payment-gateway and database credentials the same pricing engine also needs.

Real-world implementation note

Both services integrate directly with ECS task definitions, EKS via the Secrets Store CSI Driver, and Lambda environment variable encryption — the goal in any secure SDLC is zero secrets in source code, container images, or plaintext environment variables in any manifest checked into version control. Secret scanning in CI (via Snyk, GitGuardian, or native GitHub secret scanning) should be a hard merge-blocking gate, not an advisory finding.

3.4 AWS WAF

WAF is a Layer 7 web application firewall attached to CloudFront, ALB, API Gateway, AppSync, or Cognito user pools — it evaluates HTTP(S) requests against rules before they reach the application.

Mechanism

- Web ACLs contain an ordered list of rules and rule groups, each with an action (Allow, Block, Count, CAPTCHA, Challenge) — rule order and the default action matter materially, since WAF evaluates top-down and the first terminating action wins.
- AWS Managed Rule Groups (Core rule set, SQLi, known bad inputs, Linux/Windows/PHP-specific rule sets, Bot Control, Account Takeover Prevention/ATP, Account Creation Fraud Prevention/ACFP) provide a maintained baseline without writing custom rules from scratch — ATP and ACFP specifically are the managed rule groups directly relevant to a multi-tenant SaaS login/signup surface.
- Custom rules support rate-based rules (block an IP exceeding N requests in a rolling window) and rules built on the full request context (headers, query string, body, JA3/JA4 TLS fingerprint) combined via logical operators.
- Labels and rule group nesting: rules can apply a label without blocking, and later rules in the same Web ACL can match on labels applied earlier — this is how layered logic is built without one monolithic rule trying to express it all.

Real-World Implementation Scenarios**BANKING / FINANCIAL SERVICES**

ATP managed rules protecting the online-banking login endpoint

A bank's online-banking login endpoint sits behind a WAF Web ACL with Account Takeover Prevention enabled specifically against credential-stuffing attempts using credentials leaked from unrelated third-party breaches — ATP's compromised-credential matching flags and challenges login attempts using known-breached username/password pairs even on the very first attempt, before any rate-based rule would have triggered on request volume alone, which matters because credential-stuffing tools increasingly distribute attempts across thousands of low-volume-per-IP sessions specifically to stay under rate-based thresholds.

SAAS / MULTI-TENANT PLATFORM**Per-tenant rate limiting using a custom header instead of source IP**

A B2B SaaS platform serving large enterprise customers from shared corporate egress IPs found that standard per-source-IP rate-based rules were both too lenient (a malicious actor distributing requests across many IPs evades the limit) and too strict (an entire enterprise customer's office network sharing one egress IP could trip the limit during legitimate peak usage). The platform's WAF rule instead rate-limits on a custom header containing the authenticated tenant ID, set by the application's edge layer after token validation — giving accurate per-tenant throttling regardless of how many physical source IPs a given tenant's users connect from.

E-COMMERCE**Bot Control blocking inventory-scalping bots ahead of a limited-release product drop**

An e-commerce retailer running a limited-quantity sneaker-drop style release enables WAF Bot Control's targeted mode specifically on the product page and checkout endpoints for the 48-hour window around the drop, blocking automated scalping bots attempting to bulk-purchase inventory faster than legitimate customers can complete a manual checkout — a control the retailer explicitly does not run year-round because Bot Control's targeted mode has a real latency and cost overhead not justified outside high-value, high-bot-interest events.

Real-world implementation for multi-tenant SaaS

The highest-value WAF pattern for a multi-tenant SaaS app is combining rate-based rules scoped per-tenant-identifying header (not just per source IP) with ATP on the login endpoint specifically, and routing all WAF block/challenge events into the same detection pipeline as GuardDuty findings so a spike in blocked requests against one tenant's subdomain is visible to the same on-call rotation that handles infrastructure alerts.

Limitations and alternatives

WAF is request-pattern-based; it has no behavioral baseline of normal for a given application without significant custom rule investment. Cloudflare WAF is the most common alternative/complement in real deployments — many SaaS companies run Cloudflare in front of AWS specifically for its bot mitigation maturity and broader edge network for DDoS absorption, with AWS WAF then acting as a second, more application-aware layer closer to the origin.

3.5 AWS Shield (Standard & Advanced)

Shield Standard is automatically active on every AWS account at no cost and provides protection against common, automated network and transport layer (L3/L4) DDoS attacks for CloudFront, Route 53, and other edge services. Shield Advanced is a paid tier adding L7 protection, near-real-time attack visibility, dedicated DDoS Response Team (DRT) access, and cost protection — reimbursing scaling costs incurred specifically due to a DDoS event.

Real-World Implementation Scenarios**BANKING / FINANCIAL SERVICES**

DRT engagement during a sustained volumetric attack on public-facing banking infrastructure

A bank's public-facing online-banking platform experiences a sustained, multi-vector DDoS attack timed to coincide with a period of public scrutiny of the institution. Shield Advanced's DRT is engaged directly, providing real-time mitigation guidance and custom mitigation rule deployment beyond what the bank's own team had configured — and Shield Advanced's cost protection later reimburses the CloudFront and ELB scaling charges incurred during the attack window, which were significant given the attack's duration.

SAAS / MULTI-TENANT PLATFORM**Cost-protection guarantee justifying Shield Advanced ahead of a funding-driven usage spike**

A fast-growing SaaS platform anticipating a major product launch and associated press coverage subscribes to Shield Advanced specifically for its cost-protection guarantee, reasoning that the unpredictable mix of legitimate viral traffic and opportunistic attack traffic during a high-visibility launch window makes the subscription cost trivial relative to the risk of an uncapped autoscaling bill if a DDoS attempt coincides with genuine demand and the platform can't easily distinguish the two in the first hours.

E-COMMERCE**Layering Shield Advanced under an existing Cloudflare deployment for defense in depth**

An e-commerce retailer already running Cloudflare in front of AWS for CDN and primary DDoS absorption adds Shield Advanced specifically as a second layer covering the direct-to-origin path, reasoning that a sufficiently sophisticated attacker who discovers the AWS origin IP (bypassing Cloudflare entirely via direct connection) should still face AWS-native DDoS protection rather than an unprotected origin — a defense-in-depth decision rather than redundant spend, since the two layers protect against different attack paths.

- **Alternatives:** Cloudflare's DDoS protection is the dominant alternative/complement, and for companies running Cloudflare in front of AWS already for WAF/CDN reasons, Cloudflare's network-edge absorption typically means many attacks never reach AWS Shield's layer at all.

3.6 AWS Network Firewall

A managed, stateful network firewall deployed inside a VPC, built on the open-source Suricata engine — it supports full Suricata-compatible rule syntax, intrusion detection/prevention (IDS/IPS) signature-based rules, domain-based filtering, and TLS inspection (decrypt, inspect, re-encrypt) for outbound traffic.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES**Domain allow-listing for outbound traffic from the core-banking processing VPC**

A bank's core-banking transaction-processing VPC routes all outbound traffic through a centralized inspection VPC running Network Firewall configured in strict allow-list mode — only a specific, documented list of external domains (the core-banking vendor's API endpoints, a small number of regulatory reporting endpoints) is permitted outbound, with every other destination denied by default, directly limiting the blast radius of a supply-chain compromise in any third-party dependency attempting to phone home to an unapproved domain.

SAAS / MULTI-TENANT PLATFORM**IDS/IPS signature detection catching a compromised dependency's C2 beacon**

A SaaS platform's centralized Network Firewall, running IDS/IPS signatures against all egress traffic from the application VPCs, flags a pattern consistent with a known command-and-control beacon originating from a build-tooling EC2 instance shortly after a routine dependency update — the centralized egress architecture means this detection happens once, centrally, rather than requiring every application VPC to have run its own independent IDS, and the instance is isolated within minutes of the signature match via the automated response pipeline described in Section 5.

E-COMMERCE

TLS inspection on outbound traffic from a checkout service following a third-party tag-manager incident

After an industry-wide incident involving a compromised third-party JavaScript tag-manager script exfiltrating checkout-page form data, an e-commerce retailer enables targeted TLS inspection via Network Firewall specifically on outbound traffic from the checkout service's backend (not the browser-side traffic, which is a separate concern, but the server-side calls that service makes outbound) to verify none of its own backend integrations were exfiltrating data through an unexpected destination — a deliberately narrow, temporary use of TLS inspection given its operational overhead, rather than a blanket policy.

- Limitations: it operates within VPC boundaries and is not a substitute for a true next-gen firewall's application-layer awareness across non-HTTP protocols, and TLS inspection adds real operational complexity that should be scoped carefully rather than enabled blanket.
- Alternatives: third-party firewall appliances from the AWS Marketplace (Palo Alto VM-Series, Fortinet, Check Point) offer more advanced application-layer inspection and centralized multi-cloud management consoles, at higher cost and operational overhead than the AWS-native managed service.

3.7 Security Groups, NACLs & VPC Architecture

These are foundational but routinely misunderstood at the level of detail that actually matters for a security architecture review.

Security Groups	Stateful, instance/ENI-level. Only support Allow rules (no explicit Deny) — to block something, you simply don't allow it, which means the most permissive applicable rule wins for any given evaluation.
Network ACLs (NACLs)	Stateless, subnet-level. Support both Allow and Deny rules evaluated in numbered order, and being stateless, require explicit rules for return traffic — the classic NACL misconfiguration is allowing outbound on an ephemeral port range but forgetting the corresponding inbound rule for the response.
Security Group referencing	Referencing another security group as the source/destination (rather than a CIDR) in a rule means the rule automatically applies to any instance that group is attached to, present or future — this is what makes security group design scale cleanly across autoscaling fleets.
VPC Endpoints (Interface & Gateway)	Interface endpoints (PrivateLink) and Gateway endpoints (S3, DynamoDB) let traffic to AWS services stay on the AWS network backbone instead of routing through a NAT Gateway or Internet Gateway — workloads in fully private subnets with no internet route can still reach S3, KMS, Secrets Manager, and other AWS APIs via endpoints.
PrivateLink for SaaS multi-tenancy	PrivateLink also enables exposing a service to other VPCs/accounts (including customer-owned VPCs) without any of the traffic touching the public internet or requiring VPC peering — the standard pattern for SaaS companies offering customers a private connectivity option into the platform.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

PrivateLink connectivity for a corporate-treasury customer requiring no public-internet path

A bank's corporate-treasury management product, sold to large enterprise customers, offers a PrivateLink endpoint as the only supported connectivity option for customers whose own internal security policy prohibits any treasury-system traffic from traversing the public internet — the bank exposes its API service via a VPC endpoint service, and each enterprise customer creates an interface endpoint in their own VPC, so the entire data path stays on the AWS backbone end-to-end with no public IP involved at any point.

SAAS / MULTI-TENANT PLATFORM**Security-group-referencing for a horizontally scaled microservice mesh**

A SaaS platform's internal microservice architecture uses security-group-referencing exclusively for service-to-service rules (the order service's security group allows inbound from the inventory service's security group, by reference, rather than by CIDR) so that as both services autoscale up and down throughout the day, every new instance automatically inherits the correct access rules with zero manual security-group maintenance — eliminating an entire historical class of outage where a scaled-out instance briefly couldn't reach a dependency because its IP wasn't yet in a CIDR-based rule.

E-COMMERCE**Gateway VPC endpoint enforcing that product-catalog data never traverses the public internet, even internally**

An e-commerce platform's product-catalog data lives in S3 and is read by application servers in fully private subnets with no NAT Gateway or internet route at all, reachable only via an S3 Gateway VPC endpoint — combined with a bucket policy condition restricting access to that specific VPC endpoint, this guarantees catalog data retrieval never has a network path through the public internet even if an application server's IAM credentials were somehow exposed externally and used from outside the VPC, since the bucket policy itself would deny the request.

Architecture pattern worth calling out explicitly

A mature multi-account VPC design uses Transit Gateway as the central hub connecting spoke VPCs, with a dedicated inspection VPC for centralized Network Firewall egress filtering and a dedicated endpoints VPC or per-spoke endpoints for private AWS service access — this is the reference pattern most architecture review boards converge on once a platform outgrows simple single-VPC-per-environment design.

3.8 AWS Certificate Manager (ACM)

ACM issues and automatically renews public and private TLS certificates for use with integrated AWS services (CloudFront, ALB/NLB, API Gateway). The operational value is almost entirely in the automatic renewal — certificates provisioned through ACM for use with supported integrated services renew without any action required, eliminating the expired-certificate-causes-an-outage failure mode.

- Private CA (ACM Private CA): a managed private certificate authority for issuing certificates for internal mTLS use cases — service-to-service authentication inside a service mesh, IoT device identity, or internal-only endpoints.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES**Private CA issuing mTLS certificates for service-to-service auth between core-banking microservices**

A bank running a service mesh between its core-banking microservices uses ACM Private CA as the root of trust for the mesh's automatic mTLS certificate issuance and rotation, so every service-to-service call inside the regulated transaction-processing environment is mutually authenticated at the transport layer — and the Private CA's certificate issuance is itself logged to CloudTrail, giving an auditable record of every service identity ever issued a certificate, which the bank's auditors specifically requested as evidence of internal network segmentation.

SAAS / MULTI-TENANT PLATFORM**Automatic renewal eliminating a historical class of customer-facing outage**

A SaaS platform serving custom domains for enterprise customers (each customer can point their own subdomain at the platform) previously suffered an outage when a manually-managed certificate for one customer's custom domain expired without anyone noticing. Migrating custom-domain certificate issuance to

ACM, integrated with CloudFront, eliminated the entire failure category — renewal is automatic and silent as long as the DNS validation records remain in place, removing a recurring operational fire drill entirely.

E-COMMERCE

Public ACM certificates across dozens of regional storefront domains

An e-commerce company operating dozens of country-specific storefront domains (a separate domain per major market) uses ACM to issue and auto-renew a certificate per domain attached to each region's CloudFront distribution, with DNS validation automated via Route 53 — meaning launching a new country storefront no longer requires a manual certificate request and validation step in the launch checklist, removing what had previously been one of the longer lead-time items in opening a new market.

3.9 Amazon Cognito

Cognito is AWS's managed customer-identity (CIAM) service — distinct in purpose from IAM Identity Center, which is workforce identity. Cognito User Pools handle sign-up, sign-in, MFA, and token issuance for an application's end users; Identity Pools separately exchange a verified identity for temporary, scoped AWS credentials when end users need direct, limited AWS access.

Mechanism relevant to multi-tenant SaaS

- User Pools issue standard OIDC-compliant ID tokens and OAuth 2.0 access tokens (JWTs), and support SAML and OIDC federation so enterprise customers can bring their own IdP for SSO into the application.
- Custom attributes and pre-token-generation Lambda triggers are how a `tenant_id` gets embedded into the issued JWT — this is the linchpin connecting Cognito's authentication output to the application's and IAM's authorization logic.
- Advanced security features (compromised credential detection, adaptive/risk-based authentication, Managed Login) reduce account-takeover risk without custom development.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Adaptive authentication stepping up MFA for anomalous login context

A digital-only challenger bank uses Cognito's adaptive authentication so a login attempt from a new device, an unfamiliar geographic location, or a login immediately following a password-reset event automatically triggers a step-up MFA challenge beyond the customer's normal single-factor flow — without the bank's engineering team having to build custom risk-scoring logic, since this is exactly the account-takeover risk pattern adaptive authentication is designed to catch.

SAAS / MULTI-TENANT PLATFORM

Pre-token-generation Lambda embedding `tenant_id`, feeding the IAM ABAC chain end-to-end

Directly connecting back to the IAM and KMS scenarios above: a B2B SaaS platform's Cognito User Pool uses a pre-token-generation Lambda trigger to look up the authenticated user's tenant membership and embed a `tenant_id` custom claim into the issued JWT — that claim then becomes the session tag passed at STS AssumeRole, becomes the IAM ABAC condition, and becomes the KMS key-policy-enforced tenant boundary, meaning a single, carefully reviewed Lambda trigger is the one place where tenant identity enters the entire downstream authorization chain, and is treated with the same code-review and testing rigor as the platform's core authorization logic precisely because every later control depends on this claim being correct.

E-COMMERCE

SAML federation supporting a B2B wholesale customer's corporate SSO requirement

An e-commerce platform's B2B wholesale ordering portal, used by corporate procurement teams at large retail-chain customers, supports SAML federation through Cognito so each wholesale customer's procurement staff log in via their own company's Okta or Entra ID instance rather than the e-commerce

platform managing separate credentials for hundreds of individual procurement employees across dozens of corporate customers — a sales requirement several large wholesale accounts had made a condition of the contract.

Where it falls short / alternatives

Cognito's customization ceiling is real — complex custom authentication flows or advanced fraud signals beyond the built-in features tend to push mature SaaS platforms toward Auth0 (Okta-owned) or WorkOS specifically for B2B SSO/SCIM provisioning UX, both of which offer a more polished enterprise-IdP-onboarding self-service experience than Cognito's more infrastructure-oriented configuration model.

3.10 AWS CloudHSM

CloudHSM provisions dedicated, single-tenant FIPS 140-2 Level 3 validated hardware security modules inside a VPC — in contrast to KMS, where the HSM fleet is shared (logically isolated) across customers, CloudHSM gives exclusive hardware control, including full administrative control of the HSM's own users and key material, which AWS itself cannot access.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Dedicated HSM custody for payment HSM operations requiring single-tenant hardware

A bank's card-issuing operation requires PIN-block translation and card-verification-value generation under a payment-network certification that explicitly mandates single-tenant HSM custody, not a shared (even logically isolated) HSM fleet — CloudHSM, configured as a KMS custom key store so the bank's broader application estate can still use standard KMS API calls, satisfies the certification's hardware custody requirement while keeping the operational simplicity of KMS for everything else.

SAAS / MULTI-TENANT PLATFORM

CloudHSM as a KMS custom key store for an enterprise customer's bring-your-own-key contractual requirement

A SaaS platform's largest enterprise customer's contract requires that their data encryption key material reside in hardware the customer's own security team has visibility into, not a fully AWS-managed multi-tenant HSM fleet. The platform stands up a dedicated CloudHSM cluster as a KMS custom key store specifically for that one customer's tenant-scoped CMK, satisfying the contractual requirement without re-architecting the rest of the platform's standard KMS-based encryption for every other tenant.

E-COMMERCE

Evaluating CloudHSM for tokenization key custody and choosing KMS instead

An e-commerce platform's PCI compliance team evaluates whether their payment-tokenization key material needs CloudHSM-level dedicated hardware custody, and after review with their QSA, determines that KMS's FIPS 140-2 Level 3 validated, logically-isolated shared HSM fleet satisfies their specific PCI SAQ scope without the added operational burden of CloudHSM cluster management — documented explicitly as a risk-based decision rather than defaulting to the more expensive option out of an assumption that dedicated hardware is automatically required for payment data.

- Trade-off: significantly higher cost and operational burden than KMS — you are responsible for HSM cluster availability, user/key administration, and backup, none of which KMS requires of you. The decision should be driven by an explicit compliance requirement, not a general sense that dedicated hardware is inherently more secure.

3.11 S3 Security Controls

Because S3 is both the most common source of high-profile cloud data exposure incidents historically and the most heavily used storage service in nearly every AWS estate, its security controls deserve specific, non-generic treatment.

S3 Block Public Access (BPA)	Four independent settings settable at the account or bucket level. Account-level BPA, enforced org-wide and locked via SCP against being disabled, should be the default posture — public buckets should be an explicit, reviewed exception, never a default-available option.
Origin Access Control (OAC)	The current, recommended mechanism for letting CloudFront access a private S3 origin without the bucket itself being public — supports SigV4 signing for all request types.
Default encryption (SSE-S3 / SSE-KMS)	Bucket-level default encryption ensures every object is encrypted at rest even if the uploading application forgets to specify it — SSE-KMS with a customer-managed key is the standard choice when access needs to be independently auditable and revocable via key policy.
S3 Object Lock	WORM enforcement at the object version level — governance mode or compliance mode (cannot be altered or deleted by anyone, including the root user, until retention expires). Directly relevant to ransomware resilience, covered further in Recover.
Access logging & S3 inventory	Server access logs (or CloudTrail data events for S3) provide the audit trail for who accessed what; S3 Inventory provides scheduled, queryable manifests of bucket contents and metadata.
Bucket policies + VPC endpoint conditions	Combining a bucket policy condition on the source VPC endpoint with a Gateway VPC Endpoint for S3 lets you require that access to a sensitive bucket only ever happens from within a specific VPC.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Object Lock compliance mode on regulatory record-retention buckets

A bank subject to a regulatory requirement that certain transaction records be retained, unmodifiable, for seven years uses S3 Object Lock in compliance mode on the dedicated regulatory-archive bucket, with the retention period set to match the regulatory minimum — meaning even a compromised root credential or a rogue insider with full administrative access cannot delete or alter those records before the retention period expires, which is the specific guarantee the regulation requires and that governance-mode or IAM-policy-based protection alone cannot provide.

SAAS / MULTI-TENANT PLATFORM

VPC-endpoint-restricted bucket policy ensuring tenant export data never traverses the public internet

A SaaS platform's customer data-export feature writes each tenant's exported data to a dedicated S3 prefix, with a bucket policy condition requiring that all access — including from the platform's own application servers — originate from the specific Gateway VPC Endpoint inside the production VPC, denying any request that somehow reached the bucket via the public S3 endpoint instead. This closes a subtle gap where IAM permissions alone would have allowed access from an unintended network path (for instance, a misconfigured Lambda accidentally given internet egress) even though the IAM policy was correctly scoped.

E-COMMERCE

Default SSE-KMS encryption on order and customer-profile buckets following a near-miss

After a near-miss incident where a newly created S3 bucket for a marketing analytics export was briefly left without default encryption configured (caught by Macie and Config before any sensitive data was actually

written to it), an e-commerce company adds account-level default encryption enforcement via an SCP-backed Config rule requiring every new bucket to have SSE-KMS default encryption configured at creation time — removing the dependency on individual engineers remembering to configure it correctly on every new bucket.

3.12 AWS Systems Manager — Session Manager & Patch Manager

Systems Manager (SSM) is grouped under Protect here specifically for its two highest security-relevance capabilities, separate from its broader operations/automation feature set.

- **Session Manager:** provides shell access to EC2 instances without opening any inbound port — the agent-based connection is outbound-initiated from the instance to the SSM service. Every session is logged and access is governed entirely by IAM, meaning SSH key sprawl and bastion host management are eliminated entirely.
- **Patch Manager:** automates patch baseline definition and scheduled patch application across fleets using tags/resource groups for targeting, with patch compliance reporting that feeds directly into the vulnerability management program.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Eliminating SSH bastion hosts from the cardholder-data environment entirely

A bank's PCI assessor flagged the existing SSH bastion-host architecture in the cardholder-data environment as an unnecessary persistent attack surface during the annual assessment. Migrating fully to Session Manager — removing all inbound SSH security group rules and decommissioning the bastion hosts — closed the finding by eliminating the attack surface category entirely rather than hardening it, while simultaneously giving the bank a complete, centrally logged record of every administrative session for the next audit.

SAAS / MULTI-TENANT PLATFORM

Tag-based patch baselines differentiating customer-facing fleets from internal tooling

A SaaS platform's Patch Manager configuration uses two distinct patch baselines targeted by resource tag — a fast, automated patch baseline for internal tooling instances that can tolerate occasional reboots with minimal coordination, and a slower, canary-style phased baseline for customer-facing application servers that patches a small percentage of the fleet first, monitors error rates for an hour, then proceeds — preventing a bad patch from simultaneously affecting the entire customer-facing fleet the way an unphased, blanket patch policy would.

E-COMMERCE

Session Manager access logging supporting a fraud-investigation chain of custody

During an internal investigation into a suspected insider-assisted fraud scheme involving manual database access, an e-commerce company's security team relies on Session Manager's complete logged history of every interactive session on the relevant database host — including exact commands run and timestamps — to establish a chain of custody for the investigation, something the company's previous SSH-key-based access model could never have reliably reconstructed since SSH access itself wasn't centrally logged at the command level.

- Alternatives: Teleport and StrongDM are common third-party alternatives specifically when the org needs unified, audited access across heterogeneous infrastructure (AWS, on-prem, Kubernetes, databases) under one access broker rather than relying on each cloud's native session tooling separately.

3.16 Protect Function — Summary Table (Part 1)

Service	Primary Role	Pairs With / Alternatives
IAM	Identity & access control plane	IAM Identity Center, Access Analyzer, CIEM tools
KMS	Encryption key management, CMEK	CloudHSM, XKS, Secrets Manager
Secrets Manager / Parameter Store	Secrets & config storage, rotation	ECS/EKS secrets integration, CI secret scanning
WAF	L7 application protection	Cloudflare WAF, Shield
Shield Standard/Advanced	DDoS protection (L3/L4, L7)	Cloudflare, WAF
Network Firewall	VPC-level stateful inspection, IDS/IPS	Transit Gateway hub-spoke, Palo Alto/Fortinet
Security Groups / NACLs	Instance and subnet-level network controls	VPC endpoints, Transit Gateway
Certificate Manager	TLS certificate issuance & renewal	Private CA, service mesh mTLS
Cognito	Customer identity (CIAM), B2B SSO	Auth0, WorkOS
CloudHSM	Dedicated single-tenant HSM	KMS (shared HSM), KMS Custom Key Store
S3 security controls	Data-at-rest protection, public access prevention	Macie, Object Lock, VPC endpoints
Systems Manager (Session/Patch Manager)	Agent-based host access & patching	Teleport, StrongDM

3.13 Amazon CloudFront

CloudFront is AWS's CDN, and from a security architecture standpoint it is far more than a caching layer — it is the edge enforcement point where WAF, Shield, geo-restriction, signed URLs, and origin-access control all converge before a request ever reaches origin infrastructure. Treating CloudFront purely as a performance optimization rather than a security control undersells what it's actually doing in a well-designed architecture.

Mechanism

Origin Access Control (OAC)	Ensures a private S3 origin (or other origin) is only reachable through CloudFront, never directly — the bucket itself has no public access at all, and CloudFront's SigV4-signed requests are the only valid access path. This is the standard pattern for serving any private content (tenant-uploaded files, generated reports) without ever making the underlying bucket public.
Signed URLs and Signed Cookies	Time-limited, cryptographically signed access grants for specific objects or paths — the mechanism for giving a specific user temporary access to a specific private resource (a generated invoice PDF, a video the user purchased) without making the resource broadly accessible or routing every request through the application origin just to check authorization.
Field-Level Encryption	Encrypts specific sensitive fields (e.g., a payment field in a POST body) at the CloudFront edge using a public key, so the data is encrypted before it even reaches the origin server — meaning even if the origin application has a logging misconfiguration that would otherwise capture the raw field in a log, the field was already encrypted before arriving.

Geo-restriction	Allow-list or deny-list specific countries at the edge, before any request reaches origin — relevant both for licensing/sanctions compliance and for simply shrinking the attack surface from regions with no legitimate user base for a given product.
Response headers policy & security headers	CloudFront can inject standard security headers (Strict-Transport-Security, Content-Security-Policy, X-Frame-Options) centrally at the edge across every distribution, rather than relying on every origin application to set them correctly and consistently.
Origin Shield	An additional caching layer that reduces direct origin load and, as a side effect, reduces the origin's exposure to request volume during a volumetric event, since fewer requests reach origin even when CloudFront's edge caches are being hit hard.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Signed URLs gating access to generated account statements

A bank's online-banking portal generates monthly account statement PDFs and stores them in a private S3 bucket behind CloudFront with OAC. When a customer requests their statement, the application backend verifies the customer's session and entitlement, then generates a CloudFront signed URL valid for five minutes scoped to that exact object — meaning the statement is never broadly accessible, the URL is useless if intercepted after the validity window, and there is no path by which one customer could enumerate or guess another customer's statement URL, since each is generated fresh per authorized request rather than being a static, guessable path.

SAAS / MULTI-TENANT PLATFORM

Per-tenant cache isolation and signed cookies for a multi-tenant document-sharing feature

A B2B SaaS platform's document-sharing feature lets a tenant's users share internal documents via a link. CloudFront signed cookies, scoped per document and tied to a short-lived session established after the platform's own authorization check, gate access to the underlying private S3 objects — and the cache key policy is explicitly configured to vary by an authorization-context header, preventing the dangerous failure mode where CloudFront might otherwise serve one tenant's cached private document to a different tenant's request due to a cache key that didn't account for tenant or authorization context.

E-COMMERCE

Field-level encryption protecting gift-card PIN entry during a checkout integration migration

An e-commerce retailer's checkout flow briefly needed to pass a gift-card PIN field through to a legacy validation service during a phased migration to a new payment platform. Rather than risk that sensitive field appearing in plaintext in any origin-side request log during the transition period, the team enables CloudFront field-level encryption on that specific field, so it's encrypted at the edge using a key only the legacy validation service holds — a deliberately temporary, scoped control for the migration window rather than a permanent architecture decision.

Where it falls short / limitations

- CloudFront's WAF integration and security headers operate at the edge, but CloudFront itself has no application-layer understanding of business logic — a signed URL correctly limits access to an object, but it cannot enforce that the object's contents are appropriate for the requesting tenant; that's still an application-layer responsibility upstream of the signing decision.
- Cache misconfiguration is a recurring, underappreciated security risk specifically in multi-tenant contexts — a cache key policy that doesn't vary by the right request attributes (auth context, tenant identifier) can cause CloudFront to serve one user's personalized or private response to a different user, which is a data-

exposure bug that looks like a caching bug and is often missed in security review because it's filed under performance engineering rather than security architecture.

Alternatives

Cloudflare is the dominant alternative/complement, frequently chosen as the primary CDN and edge security layer (with its more mature bot management and broader network) while CloudFront remains in use for AWS-native origin integrations (private S3 content, Lambda@Edge/CloudFront Functions for lightweight edge logic). Fastly is a third common option, particularly favored for its more sophisticated real-time purging and edge-compute model in media and high-traffic e-commerce contexts.

3.14 Amazon Route 53

Route 53 is AWS's DNS service, and its security relevance extends well beyond simple resolution — DNS is both a frequent attack vector (DNS hijacking, cache poisoning, subdomain takeover) and an increasingly important detection surface (DNS query logs reveal malware C2 beaconing and data exfiltration attempts that other logs miss).

Mechanism

DNSSEC	Cryptographically signs DNS responses so resolvers can verify a response actually came from the authoritative source and wasn't tampered with in transit — directly defends against DNS spoofing/cache-poisoning attacks that could otherwise redirect users to an attacker-controlled endpoint while the domain name itself appears correct.
Route 53 Resolver DNS Firewall	A managed DNS filtering layer that blocks resolution of known-malicious domains (using AWS-managed threat lists or custom domain lists) for any resource inside the VPC — meaning malware attempting to resolve a C2 domain from inside the network simply fails to resolve, often before any other detective control would have caught the connection attempt.
Resolver query logging	Captures every DNS query made from within VPCs using Route 53 Resolver — frequently the earliest and clearest signal of compromise, since malware C2 beaconing and DNS-based exfiltration techniques both depend on DNS queries that look anomalous against a baseline of normal application DNS behavior, well before any other log source would show something is wrong.
Subdomain takeover prevention	Route 53 alias records pointing to decommissioned AWS resources (an old CloudFront distribution, a deleted S3 bucket used for static hosting, an old ELB) are a classic subdomain-takeover vector if the DNS record is left dangling after the resource is deleted — disciplined DNS record lifecycle management, ideally automated via IaC so DNS records are destroyed in the same pipeline that destroys the underlying resource, is the actual control here, not a Route 53 feature per se.
Health checks & failover routing	While primarily an availability feature, health-check-based failover routing is also a security-adjacent control during an active incident — automatically routing traffic away from a compromised or actively-being-attacked endpoint to a clean standby without manual DNS changes under pressure.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

DNSSEC protecting the public-facing banking domain against cache-poisoning redirection

A bank enables DNSSEC on its primary public-facing domain specifically to close a theoretical but regulator-flagged risk: a successful DNS cache-poisoning attack against an ISP-level resolver redirecting customers attempting to reach the bank's legitimate domain to a phishing site with a valid-looking but attacker-controlled IP — DNSSEC doesn't prevent every phishing vector, but it closes this specific class of attack by letting validating resolvers cryptographically reject a forged response, and control the bank's regulator specifically asked about following industry-wide DNS-hijacking incidents at other institutions.

SAAS / MULTI-TENANT PLATFORM

DNS Firewall blocking a compromised dependency's beaconing attempt across the whole VPC

Directly extending the Network Firewall scenario from Section 3.6: a SaaS platform's Route 53 Resolver DNS Firewall, configured with both the AWS-managed malware domain list and a custom block list maintained by the detection engineering team, blocks a DNS resolution attempt from a CI/CD build agent toward a domain that was registered only days earlier and matched a heuristic pattern associated with malware staging infrastructure — the resolution failure itself becomes the detection event, surfaced via Resolver query logs into the same Tines pipeline used for GuardDuty findings, catching the compromised build dependency before any actual outbound connection could succeed.

E-COMMERCE

Catching a dangling subdomain before it could be claimed by an attacker

An e-commerce company's marketing team decommissioned an old promotional microsite, deleting the underlying S3 bucket and CloudFront distribution but — because the DNS record deletion wasn't part of the same automated teardown pipeline — leaving a dangling CNAME record pointing to the now-nonexistent CloudFront distribution. A routine DNS hygiene audit (a quarterly Route 53 record review specifically looking for alias/CNAME targets that no longer resolve to an owned resource) catches the dangling record before an attacker could register a new CloudFront distribution and claim the now-orphaned hostname to host phishing content under the company's own trusted subdomain.

Real-world implementation note

Resolver query logging is one of the most underused high-value log sources in AWS. Routing it into the same SIEM or detection pipeline as VPC Flow Logs and GuardDuty findings, and specifically building a detection rule for DNS queries to newly-registered domains (a strong malware-staging indicator) or to domains with unusually high query entropy (a DNS-tunneling indicator), catches threat activity that purely IP-based network detection frequently misses entirely.

Alternatives

Cloudflare DNS is the common alternative when an organization wants a single vendor for DNS, CDN, and WAF together, with Cloudflare's own DNS-layer security features (similar in spirit to DNS Firewall) bundled in. For enterprises with existing on-prem DNS infrastructure, Infoblox remains common for unified DNS/DHCP/IPAM management across hybrid environments, with Route 53 handling only the AWS-hosted public zones.

3.15 AWS Firewall Manager

Firewall Manager is the central policy-management layer for WAF, Shield Advanced, Network Firewall, VPC security groups, and Route 53 Resolver DNS Firewall across an entire AWS Organization — its function is purely orchestration and enforcement consistency, not a new detection or filtering engine of its own. The problem it solves: WAF rules, security group standards, and Network Firewall policies configured independently per account inevitably drift, and a security team has no reliable way to guarantee every account actually has the baseline protections applied without checking each one individually.

Mechanism

- Security policies defined once in the Firewall Manager administrator account (typically the same delegated-admin Security Tooling account used for GuardDuty and Security Hub) are automatically applied to every

account and resource matching a defined scope (an OU, a tag, an account list) — and critically, Firewall Manager continuously enforces the policy, automatically remediating or re-applying it if a resource owner attempts to remove or modify the centrally-mandated rule.

- Mandatory WAF policies can attach a baseline managed rule group (e.g., the Core rule set and a known-bad-inputs rule group) to every internet-facing ALB and CloudFront distribution across the org automatically, including newly created ones — meaning a team standing up a brand-new public-facing ALB gets baseline WAF protection the moment it's created, without needing to remember to attach a Web ACL themselves.
- Security group policies can audit and automatically remediate non-compliant security groups org-wide — for example, auto-remediating any security group found with unrestricted inbound access on a defined list of high-risk ports, removing the offending rule without waiting for a human to act on a Config or Security Hub finding.
- Shield Advanced policies ensure DDoS protection is applied consistently to every defined resource type across every account, which matters because Shield Advanced's protection has to be explicitly associated with a resource — without Firewall Manager centrally enforcing this, individual teams provisioning new internet-facing resources can easily forget the association step entirely.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Guaranteeing baseline WAF coverage across every public endpoint in a 60-account banking estate

A bank operating roughly 60 AWS accounts across retail banking, wealth management, and a payments subsidiary uses Firewall Manager to mandate that every internet-facing ALB and CloudFront distribution in the organization automatically receives the bank's baseline WAF rule set (Core rule set, SQLi protection, and the bank's own custom rule blocking a specific set of known fraud-tool user agents) the moment it's created — closing a real, previously recurring audit finding where individual product teams had occasionally launched new public endpoints without remembering to attach any WAF protection at all, since there had been no organization-wide enforcement mechanism before.

SAAS / MULTI-TENANT PLATFORM

Auto-remediating security groups across 200+ service-owning accounts without waiting on each team

A SaaS platform running the service-per-account model described earlier in this document uses a Firewall Manager security group policy to continuously audit every account for any security group permitting unrestricted inbound access on database ports (3306, 5432, 1433) — and configures it in auto-remediation mode, so the offending rule is automatically removed the moment it's detected rather than waiting for the owning team to act on a ticket, which matters because in a 200-account estate relying on every individual team to promptly act on a Config or Security Hub finding had proven to be the slowest and least reliable step in the remediation pipeline.

E-COMMERCE

Centrally mandating Shield Advanced association ahead of peak season across every regional storefront account

An e-commerce company running separate AWS accounts per regional storefront (extending the Route 53 and CloudFront scenarios above) uses a Firewall Manager Shield Advanced policy to guarantee that every CloudFront distribution and ALB tagged as a production storefront, in every regional account, has Shield Advanced protection associated — catching, ahead of the peak holiday season, two newer regional storefront accounts where the team had correctly configured WAF but had never explicitly associated Shield Advanced, an easy step to miss since it requires a separate, additional action beyond standard resource provisioning.

Where it falls short

- Firewall Manager is an enforcement and consistency layer, not a detection or analysis tool — it has no risk-scoring or exposure-graphing capability of its own, and the policies it enforces are only as good as the rule sets and security group standards defined within them.
- It requires Organizations and a delegated administrator account to be set up correctly first; it is not useful in a single-account or loosely federated multi-account environment without that foundation already in place.

Alternatives

There is no direct AWS-native alternative for this specific cross-account policy enforcement role — the alternative is building equivalent enforcement via Config rules with auto-remediation Lambdas, or via Terraform/Sentinel policy-as-code gates at deploy time, both of which require considerably more custom engineering to achieve the same continuous, centrally-enforced consistency Firewall Manager provides out of the box. For multi-cloud organizations, Wiz and Prisma Cloud's policy enforcement modules provide a comparable cross-cloud consistency layer, though with less direct, native control over the underlying WAF/Shield/Network Firewall resources themselves than Firewall Manager has as the AWS-native tool.

4. DETECT

Detect is where raw telemetry becomes an actionable signal. The discipline that separates a mature detection program from a noisy one is not which AWS services are enabled — it's whether findings are correlated, enriched with business context, and routed to the right response path automatically. This section covers the AWS-native detection sources; Section 6 covers how those signals get orchestrated into response.

4.1 Amazon GuardDuty

GuardDuty is AWS's managed threat detection service — it is the single highest-value native detection control in almost every AWS estate because of what it requires to operate: nothing. It analyzes existing data sources (VPC Flow Logs, DNS query logs, CloudTrail management and data events, EKS audit logs, RDS/Aurora login activity, Lambda network activity, S3 data events) without requiring any agent deployment, log shipping configuration, or storage cost beyond GuardDuty's own per-event pricing.

Detection mechanism

- Threat intelligence matching: known malicious IPs, domains, and file hashes matched against observed network and DNS traffic.
- Anomaly detection via machine learning: baselines normal behavior per account/resource and flags statistically anomalous deviations — this is what catches novel threats that wouldn't match any static signature.
- Protection plans: EKS Protection (audit log analysis plus optional Runtime Monitoring via an eBPF-based agent for in-cluster behavioral detection), S3 Protection (data event analysis for anomalous access/exfiltration patterns), RDS Protection (anomalous login activity against Aurora), Lambda Protection, and Malware Protection (agentless scanning triggered on a relevant finding).
- Extended Threat Detection: correlates findings across multiple data sources and over time into a single higher-confidence attack-sequence finding rather than leaving an analyst to manually connect several disconnected lower-severity findings.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

EKS Runtime Monitoring catching a container-escape attempt in a Kubernetes-hosted fraud-scoring service

A bank's real-time fraud-scoring service runs on EKS, processing live transaction data. GuardDuty's Runtime Monitoring agent flags an anomalous process execution inside a pod — a shell spawned from within the application container attempting to access the underlying node's instance metadata service, a classic container-escape and credential-theft pattern — within seconds of the attempt, triggering automated pod isolation before the attempted escape could succeed in reaching node-level IAM credentials that would have had broader access than the pod's own scoped role.

SAAS / MULTI-TENANT PLATFORM

S3 Protection flagging anomalous cross-tenant access pattern from a compromised application credential

A SaaS platform's S3 Protection plan flags an anomalous data access pattern: an application IAM role that historically only ever read from its own tenant-scoped prefix suddenly issues a burst of GetObject calls against prefixes belonging to several other tenants, in a pattern and volume inconsistent with any legitimate application behavior — the finding triggers immediate credential revocation via the automated response pipeline, and the subsequent investigation traces it to a leaked credential from a misconfigured CI pipeline, caught by GuardDuty's behavioral baseline before any customer noticed unusual activity on their own account.

E-COMMERCE

Extended Threat Detection correlating a credential-stuffing wave with subsequent inventory-API abuse

GuardDuty's Extended Threat Detection correlates two findings that would otherwise have been triaged separately by different on-call engineers: an anomalous spike in failed authentication attempts against the customer account API (initially looking like routine credential stuffing) and, twenty minutes later, an anomalous pattern of inventory-check API calls from a newly-authenticated session using one of the handful of accounts that succeeded — combining them into a single attack-sequence finding indicating a successful account takeover being used for inventory reconnaissance ahead of a suspected reselling-bot operation, rather than two disconnected medium-severity findings neither of which alone would have triggered an urgent response.

Real-world implementation note

Enable GuardDuty org-wide via the delegated administrator pattern from day one of any new account being vested — this should be baked into Control Tower / Account Factory so there is never a window where a new account exists without GuardDuty active. The Runtime Monitoring agent for EKS specifically is worth the marginal cost in any cluster running multi-tenant or internet-facing workloads.

Limitations and alternatives

GuardDuty's anomaly models are tuned generically across AWS's customer base, not to your specific environment's baseline. CrowdStrike Falcon and SentinelOne provide EDR-grade host-level detection with richer process-tree and behavioral context, and are commonly run alongside GuardDuty rather than instead of it. For organizations standardizing detection logic across multi-cloud, a SIEM with custom detection rules (Splunk, Sentinel, Chronicle) ingesting GuardDuty findings alongside Azure/GCP-native signals is the path to single-pane cross-cloud detection content.

4.2 Security Hub — Detection Aggregation & Correlation

Covered structurally in Section 2.1; the detection-specific value is Security Hub's role as the normalization and correlation layer across every other AWS detective source. Every GuardDuty finding, every Inspector finding crossing a severity threshold, every Config rule failure, and every Access Analyzer external-access finding can land in Security Hub in the same ASFF schema — which is what makes a single EventBridge rule pattern sufficient to trigger downstream automation without writing separate integration logic per source service.

Security Hub's correlation rules can also combine multiple lower-severity findings related to the same resource into a single elevated-priority finding — directly reducing the noise problem where an analyst would otherwise see several separate medium findings on one resource instead of one finding correctly flagged as critical because of how those signals combine.

4.3 AWS CloudTrail

CloudTrail is the audit log of every API call made against an AWS account. It is the foundational forensic and detection data source; nearly every other detective control consumes CloudTrail data directly or indirectly.

Event types and what they actually capture

Management events	Control-plane operations. A dedicated multi-region, multi-account organization trail with indefinite S3-backed retention is what's actually needed for real investigations and compliance retention requirements, not the default 90-day event history view.
Data events	Object-level operations — S3 GetObject/PutObject, Lambda Invoke, DynamoDB item-level operations. Not enabled by default since cost scales with data-plane

	call volume — selectively enabling on specifically sensitive buckets or functions is the standard cost-aware pattern.
Insight events	Anomaly detection specifically on CloudTrail's own management event volume and pattern — a narrower, CloudTrail-specific anomaly detector distinct from GuardDuty's broader behavioral analysis.
Organization trail	A single trail in the management account capturing events from every member account into one centralized S3 bucket — the mechanism that makes centralized, tamper-evident logging actually work.
Log file integrity validation	Cryptographic digest files proving log files haven't been altered after delivery — relevant for any compliance regime requiring demonstrable audit log integrity.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Selective data-event logging on the cardholder-data S3 environment for forensic readiness

A bank enables CloudTrail data events specifically and only on the small set of S3 buckets within PCI scope, accepting the additional logging cost on that narrow scope specifically so that in the event of a suspected cardholder-data breach, the bank can produce a complete object-level access history for the forensic investigation and the mandatory card-network breach notification process — a capability the bank's QSA confirmed was a specific expectation for any in-scope storage, not something the default management-event trail alone would satisfy.

SAAS / MULTI-TENANT PLATFORM

Insight events catching an unusual burst of IAM policy changes during a suspected insider incident

CloudTrail Insight events flag an unusual statistical burst of IAM CreatePolicy and AttachRolePolicy calls from a single engineer's federated session, well outside that engineer's normal baseline activity pattern, occurring shortly after a tense performance-review conversation — the anomaly detection surfaces the activity for human review specifically because the volume and type of change was statistically unusual, not because any single API call was inherently suspicious, illustrating Insight events' specific value in catching the kind of slow-building insider-risk pattern that no single-event rule would trigger on.

E-COMMERCE

Log file integrity validation supporting a chargeback dispute investigation

During a large-scale chargeback dispute investigation, an e-commerce company's finance and security teams need to demonstrate to the payment processor that the order and transaction logs they're presenting as evidence have not been altered after the fact — CloudTrail's log file integrity validation, with the cryptographic digest files retained alongside the logs, provides a verifiable chain of custody for the underlying API activity, satisfying the processor's evidentiary standard for the dispute resolution.

Real-world implementation note

The CloudTrail logs bucket in the Log Archive account should have its own SCP-enforced protections beyond normal bucket security — Object Lock in compliance mode, a bucket policy denying delete even from the account's own root user except via a tightly scoped break-glass role, and replication to a separate account/region.

Alternatives / complements

CloudTrail Lake provides a managed, SQL-queryable data store for CloudTrail events without standing up Athena-over-S3 yourself. For long-term, cross-cloud correlated log analysis and custom detection content, shipping CloudTrail to a SIEM (Splunk, Sentinel, Datadog Cloud SIEM, Chronicle) remains the standard pattern for any org running detection engineering as a discipline.

4.4 Amazon CloudWatch — Security Use

CloudWatch's security relevance is as the metrics, logs, and alarming backbone that other detective controls depend on, plus its own native capability for custom detection logic via Logs Insights queries and metric filters.

- Metric filters on CloudTrail logs can trigger alarms on specific patterns — root account usage, IAM policy changes, failed console logins exceeding a threshold, security group changes — independent of and faster than waiting for a GuardDuty or Config-based detection.
- CloudWatch Logs Insights provides ad hoc query capability across log groups — frequently the first tool reached for during initial incident triage before escalating to a full SIEM-based investigation.
- Contributor Insights surfaces top-N contributors to a given metric pattern — useful for quickly characterizing the shape of a suspected abuse or attack pattern.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Real-time root-account-usage alarm bypassing the normal finding-aggregation delay

A bank configures a CloudWatch metric filter and alarm directly on the organization CloudTrail log group specifically for any root-user API call, paging the on-call security engineer within seconds via SNS — deliberately bypassing the normal Security Hub/GuardDuty aggregation pipeline (which can have a multi-minute delay) for this one specific, extremely high-severity event category, on the reasoning that root-account activity should never happen outside a documented break-glass procedure and therefore warrants the fastest possible alert path regardless of which other detective tooling might eventually also flag it.

SAAS / MULTI-TENANT PLATFORM

Logs Insights ad hoc query during initial triage of a customer-reported anomaly

A customer reports seeing unfamiliar data in their account dashboard, a potential cross-tenant data leak. Before escalating to a full incident process, the on-call engineer runs a CloudWatch Logs Insights query directly against the application's request logs, filtering for any request bearing that customer's tenant ID alongside any response payload size anomaly, getting an initial read on whether this looks like an isolated rendering bug or an actual data-access issue within minutes — informing whether to declare a security incident before the slower, more thorough SIEM-based investigation even begins.

E-COMMERCE

Contributor Insights characterizing a suspected scraping bot's request pattern

An e-commerce platform's API gateway logs feed Contributor Insights to identify the top contributing user agents and source ASNs behind an unusual spike in product-page requests — quickly confirming the traffic is concentrated among a small number of ASNs associated with commercial scraping infrastructure rather than being organic traffic growth, which informs the decision to deploy a targeted WAF rate-based rule against those specific ASNs rather than a blanket rule that would also affect legitimate users.

4.5 Amazon Detective

Detective addresses a specific, real operational gap: GuardDuty tells you something suspicious happened; Detective is built for the next question, which is almost always what else did this resource, IP, or role do, before and after this finding, and is it connected to anything else.

- Mechanism: Detective continuously ingests VPC Flow Logs, CloudTrail, and GuardDuty findings and pre-builds a behavior graph spanning a rolling 12-month window — entities and the relationships and activity volume between them — so that when an analyst pivots from a GuardDuty finding into Detective, the relevant historical context is already pre-computed rather than requiring a fresh, slow query across raw logs at investigation time.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES**Tracing the full blast radius of a compromised developer credential**

Following a GuardDuty finding on anomalous API activity from a developer's federated session, the bank's incident response team pivots directly into Detective to see the pre-built behavior graph for that role — immediately surfacing every resource the role touched in the preceding 30 days, including two other accounts the same session had assumed roles into that the original GuardDuty finding alone hadn't surfaced, letting the team scope the full blast radius of the credential compromise in minutes rather than running a sequence of manual CloudTrail queries across multiple accounts under incident-response time pressure.

SAAS / MULTI-TENANT PLATFORM**Confirming an anomalous IP had no prior legitimate history before escalating**

A GuardDuty finding flags an anomalous API call pattern from an IP address the platform's infrastructure had never seen associated with that particular service role before. Detective's behavior graph instantly confirms this IP has zero prior history anywhere in the account's 12-month window — no legitimate engineer, no CI system, nothing — which is the specific piece of context that turns an ambiguous anomaly finding into a high-confidence incident escalation within minutes, rather than requiring the team to manually rule out a benign explanation first.

E-COMMERCE**Investigating whether a flagged EC2 instance had any lateral-movement connections**

After GuardDuty's Malware Protection flags a finding on a single EC2 instance in the order-processing fleet, the security team uses Detective's pre-built network connection graph to immediately see every other internal resource that instance had communicated with in the preceding weeks — confirming the instance had no unusual internal connections beyond its expected dependencies, which let the team confidently scope the incident to a single isolated instance rather than needing to assume a broader compromise and isolate the entire fleet as a precaution.

- Limitations and alternatives: Detective is AWS-scoped and works from the same underlying log sources GuardDuty does — it adds investigation speed and relationship context, not new detection signal. For investigations spanning multiple clouds or needing deeper host-level forensic detail, a dedicated DFIR toolset (Velociraptor, EDR vendor forensic tooling, or a cloud-aware platform like Mitiga) is the complement.

4.6 VPC Flow Logs

Flow Logs capture IP traffic metadata at the ENI, subnet, or VPC level — not packet content, which matters for both what it can and cannot tell an investigator.

- Direct delivery to S3 in Apache Parquet format significantly reduces both storage cost and Athena query cost/time for retrospective analysis — worth standardizing on for any new flow log configuration.
- Flow Logs are the primary raw data source GuardDuty's network-based findings and Network Firewall's flow analysis are built on — enabling them is rarely optional in any environment running GuardDuty.
- Limitation: no payload visibility means flow logs can show that a large volume of data moved to an unfamiliar external IP, but not what that data was — for that level of detail, Network Firewall's TLS inspection or host-based DLP/EDR tooling is needed.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES**Confirming the absence of unauthorized data egress following a credential exposure incident**

Following an incident where a service credential was briefly exposed in a misconfigured log statement, the bank's incident response team queries VPC Flow Logs via Athena across the relevant time window to confirm whether the exposed credential's associated network identity showed any large outbound data transfer to

unfamiliar external endpoints — finding none, which is a key piece of evidence supporting the conclusion that the exposure window closed before any actual exploitation occurred, directly informing the severity classification of the incident for the bank's mandatory disclosure assessment.

SAAS / MULTI-TENANT PLATFORM

Identifying which tenant's workload was responsible for an unexpected cross-AZ data transfer cost spike

A SaaS platform's cloud cost team notices an unexpected spike in cross-AZ data transfer costs and, working with the security team, uses VPC Flow Logs to identify the specific ENI and corresponding tenant-scoped workload responsible — distinguishing between a legitimate, if inefficient, customer workload pattern and a potential security concern, since the same flow log data answers both the cost-attribution and the security-triage question simultaneously.

E-COMMERCE

Establishing a network-traffic baseline ahead of enabling GuardDuty in a newly acquired subsidiary's accounts

Ahead of fully onboarding a newly acquired subsidiary's AWS accounts into the parent company's GuardDuty and detection pipeline, the security team enables VPC Flow Logs first and lets them run for several weeks to build a traffic baseline — surfacing several already-existing unusual traffic patterns (later determined to be a legacy, undocumented integration with a third-party logistics vendor) that needed to be understood and explicitly allow-listed before GuardDuty's anomaly detection went live, avoiding a flood of false-positive findings on day one of onboarding.

4.7 Macie & Config — Detection Angle

Both services were introduced structurally under Identify for their inventory and governance roles; their detection-relevant behavior deserves a brief separate callout.

- **Macie as a detector:** beyond initial discovery, Macie's continuous automated discovery mode functions as an ongoing detector for new sensitive data appearing in places it shouldn't — a bucket that previously contained no PII suddenly receiving a data export containing customer records is itself a detectable event worth alerting on.
- **Config rules as drift detectors:** a Config rule re-evaluating continuously catches configuration drift essentially in near-real-time, which is the mechanism that makes auto-remediation possible — the rule transitioning to non-compliant is the event Lambda or Systems Manager Automation triggers on.

4.8 Detect Function — Summary Table

Service	Primary Role	Pairs With / Alternatives
GuardDuty	Managed threat detection (network, DNS, control-plane, runtime)	CrowdStrike/SentinelOne EDR, SIEM
Security Hub	Finding normalization & correlation	EventBridge, Tines, ArmorCode
CloudTrail	API audit log, forensic source of record	CloudTrail Lake, Splunk/Sentinel
CloudWatch	Metrics, log queries, custom alarm logic	Logs Insights, Contributor Insights
Detective	Pre-built behavior graph for investigation	Velociraptor, EDR forensic tooling
VPC Flow Logs	Network traffic metadata	Network Firewall, GuardDuty

Service	Primary Role	Pairs With / Alternatives
Macie (continuous discovery)	Ongoing sensitive-data appearance detection	DSPM tools
Config rules	Real-time configuration drift detection	Lambda/SSM auto-remediation

5. RESPOND

Respond is where most security programs are weakest in practice, not because the AWS services are immature, but because building the orchestration logic connecting detection to action is genuine engineering work that's easy to defer indefinitely in favor of more visible feature work. The services below are the building blocks; the architecture pattern that ties them together is described at the end of this section.

5.1 Amazon EventBridge

EventBridge is the event bus that makes automated response possible at all — nearly every AWS security service emits events to EventBridge by default, and EventBridge rules pattern-match on event content to route matching events to targets.

- Event pattern matching supports nested JSON matching with operators (prefix, anything-but, numeric comparisons) — meaning a single rule can express a precise filter without needing custom Lambda logic just to filter.
- API destinations are the mechanism by which EventBridge pushes events to an external system like Tines directly — registering Tines's webhook receiver as an API destination means AWS-native findings land in the Tines pipeline within seconds of generation.
- Cross-account/cross-region event buses let a centralized security-tooling account receive events from every member account's default bus, complementing Security Hub's own cross-account aggregation.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Routing critical findings on cardholder-data accounts to an expedited approval path

A bank's central EventBridge bus uses a pattern match specifically for any Security Hub finding with critical severity originating from an account tagged `scope:pci` — routing those events to a dedicated, higher-priority Tines webhook that pages the PCI-scope on-call rotation directly, bypassing the standard severity-based triage queue used for the rest of the estate, since findings in cardholder-data-environment accounts carry regulatory notification timelines that the standard SLA doesn't account for.

SAAS / MULTI-TENANT PLATFORM

Cross-account event bus aggregating findings from 200+ service-owning accounts into one response pipeline

Extending the Security Hub aggregation pattern described earlier: a SaaS platform's central security-tooling account receives forwarded EventBridge events from every one of its 200+ service-owning accounts via a cross-account event bus policy, with rules routing by severity and resource tag so a single Tines pipeline can act on findings org-wide without each of the 200 individual teams needing to build or maintain their own response automation independently.

E-COMMERCE

Direct API destination from WAF block events to a fraud-operations dashboard during a known attack window

During a known active credential-stuffing campaign against its login endpoint, an e-commerce platform adds a temporary EventBridge rule routing WAF block and challenge events directly to a real-time dashboard the fraud-operations team is actively watching during the incident window, via an API destination, rather than waiting for those events to flow through the normal slower aggregation and digest pipeline — a deliberately temporary routing change scoped to the active incident, removed once the campaign subsides.

Real-world implementation note

The pattern that scales: a central EventBridge bus in the security-tooling account receives forwarded events from every member account; rules on that bus route by severity and type — critical/high findings go directly to a Tines webhook via API destination for immediate enrichment and response-workflow triggering, while lower-severity findings batch into a digest for daily or weekly review.

5.2 AWS Lambda — Automated Remediation

Lambda is the most common compute layer for AWS-native auto-remediation logic — triggered by EventBridge off a Config rule transitioning to non-compliant, a GuardDuty finding, or a Security Hub finding update, a Lambda function executes the actual remediation API calls.

- AWS Config remediation actions (via Systems Manager Automation documents) provide a managed, no-Lambda-required path for many common remediations; custom Lambda is typically reserved for logic needing more nuance than a documented Automation runbook provides.
- The critical design discipline: every destructive or access-revoking action should have a corresponding dry-run/simulation mode, an audit log entry independent of CloudTrail, and a defined rollback path.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Auto-revoking a leaked credential matched against a high-confidence pattern in a public code repository scan

A bank's GitHub secret-scanning integration flags an AWS access key accidentally committed to a public fork of an internal tool by a former contractor. The finding routes through EventBridge to a Lambda function that immediately deactivates the specific access key (not the entire IAM user, to avoid disrupting other potentially legitimate uses) and posts a notification to the security channel — a high-confidence, low-blast-radius, easily reversible action appropriate for full automation without a human approval gate given the urgency of a publicly exposed credential.

SAAS / MULTI-TENANT PLATFORM

Tag-aware remediation Lambda that behaves differently for production versus sandbox accounts

A SaaS platform's auto-remediation Lambda for overly permissive security groups checks the account's environment tag before acting — in sandbox/dev accounts, it auto-remediates immediately and notifies the owning team after the fact, while in any account tagged production, the same Lambda instead opens a Slack approval request via Tines and waits for human confirmation before making the change, reflecting a deliberate design decision that the same finding type warrants different automation postures depending on blast radius.

E-COMMERCE

Quarantining a single compromised EC2 instance in the order-processing fleet without affecting the rest of the autoscaling group

Following a GuardDuty Malware Protection finding on one instance in the order-processing autoscaling group, a Lambda function automatically detaches that specific instance from the autoscaling group (so it isn't terminated and replaced by the group's own health-check logic, which would destroy forensic evidence) and swaps its security group to an isolated quarantine group with no egress, while the autoscaling group itself launches a replacement instance to maintain capacity — containing the incident without any customer-facing impact on checkout availability.

Where it's best used vs. where a human should stay in the loop

Fully automated remediation is appropriate for high-confidence, low-blast-radius, easily-reversible actions. Anything touching production data deletion, customer-facing availability, or with meaningful false-positive risk should route through a human approval step rather than firing autonomously.

5.3 AWS Systems Manager Incident Manager

Incident Manager is AWS's native incident response coordination tool — it automates initial response, manages on-call rotations and escalation, and provides a structured timeline and chat-ops integration for incident coordination.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Automated engagement plan escalation during an after-hours core-banking availability event

A CloudWatch alarm on the core-banking transaction-processing pipeline's error rate triggers an Incident Manager response plan at 2 AM, which immediately runs a pre-approved diagnostic Automation runbook and pages the primary on-call engineer — and when that page isn't acknowledged within the defined window, automatically escalates to the secondary on-call and the engineering manager, ensuring a regulated, customer-impacting outage doesn't sit unacknowledged for the 20-30 minutes a purely manual escalation chain might take during off-hours.

SAAS / MULTI-TENANT PLATFORM

Structured incident timeline supporting a customer-facing post-incident report

Following a security incident affecting a subset of tenants, a SaaS platform's Incident Manager timeline — automatically capturing every action taken, by whom, and when, throughout the response — becomes the primary source document for the customer-facing incident report several enterprise customers contractually require within 72 hours of any security event, turning what used to be a reconstructed-from-memory writing exercise into a direct export from the tool used to run the response.

E-COMMERCE

Chat-ops integration coordinating a response during a payment-processor partial outage

When a third-party payment processor experiences a partial outage during peak shopping hours, an e-commerce company's Incident Manager response plan automatically creates a dedicated incident channel via the Chime/Slack integration, pulls in the relevant on-call engineers and the payments team lead, and posts the current automated failover status to a backup processor — keeping a fast-moving, revenue-impacting incident coordinated in one place rather than across scattered direct messages.

- Alternatives: PagerDuty and Opsgenie remain the dominant dedicated incident management platforms for organizations needing richer cross-tool integration and more mature on-call scheduling UX than Incident Manager provides — most SaaS companies of meaningful size already run one of these for general operational incidents and extend the same tool to security incidents.

5.4 AWS Step Functions — Response Orchestration

For response workflows with multiple sequential or conditional steps, Step Functions provides a managed state machine rather than building that branching logic into a single large Lambda function, with built-in retry, error-handling, and a wait-for-callback pattern for manual approval gates.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Multi-step state machine for responding to a suspected compromised privileged-access session

A bank's Step Functions workflow for a suspected compromised privileged session runs as a defined sequence: revoke the active session's temporary credentials, snapshot the affected instance's EBS volume for forensic preservation, notify the security and compliance teams in parallel, then pause and wait for human confirmation before proceeding to a deeper network isolation step — the visibility into exactly which step a given response has reached, and the built-in retry logic if the snapshot step times out, is what makes this reliable enough to trust during an actual incident rather than a monolithic Lambda function that's harder to debug mid-incident.

SAAS / MULTI-TENANT PLATFORM**Wait-for-callback approval gate before deleting a flagged tenant's potentially-malicious data export**

A SaaS platform's response workflow for a suspected data-exfiltration attempt via the customer data-export feature pauses at a wait-for-callback step after generating the relevant evidence, requiring a security engineer to explicitly approve before the workflow proceeds to revoke the export and notify the tenant's admin — since this action touches customer-facing functionality and carries real false-positive risk, the team deliberately chose not to make this step fully automated despite the technical ability to do so.

E-COMMERCE**Conditional branching based on resource tags routing production incidents differently from staging**

An e-commerce company's Step Functions remediation workflow includes a conditional branch early in the state machine checking the affected resource's environment tag — production-tagged resources route through the full evidence-preservation and approval-gated path, while staging or dev-tagged resources route through a fast, fully automated remediation path with no approval gate, letting the same workflow definition serve both contexts appropriately rather than maintaining two entirely separate automation pipelines.

5.5 WAF & Network Firewall — Active Response

Both services, introduced under Protect, have a direct response-time use beyond their standing baseline configuration.

- **WAF rate-based rules and IP sets:** during an active incident, a Lambda-managed IP set update pushed to a WAF rule referencing that set is one of the fastest available containment actions — propagating globally across CloudFront within roughly a minute.
- **Network Firewall domain lists and rule groups:** for an active outbound C2/exfiltration concern, updating a Network Firewall domain block list or Suricata rule centrally immediately cuts off that path for every spoke VPC behind it.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES**Emergency WAF IP-set block during a confirmed targeted attack against online-banking infrastructure**

Upon confirming a targeted, sustained attack from a specific set of source IPs against the online-banking login endpoint (distinct from routine background credential-stuffing noise), the bank's security team pushes an emergency update to a dedicated WAF IP set via the Lambda-managed pipeline, blocking the confirmed-malicious IPs across every CloudFront distribution globally within about a minute — faster than any infrastructure-level network change could propagate, and without needing a full change-management cycle given the active-incident context.

SAAS / MULTI-TENANT PLATFORM**Centralized Network Firewall domain block stopping outbound C2 traffic across every spoke VPC simultaneously**

Directly extending the centralized-egress scenario from Section 3.6: upon confirming a specific domain as malware command-and-control infrastructure during an active investigation, the SaaS platform's security team updates the Network Firewall domain block list once, in the central inspection VPC — immediately cutting off that outbound path for every spoke VPC across the entire multi-account estate simultaneously, rather than needing to push the same block to dozens of independently managed VPC-level firewalls one at a time.

E-COMMERCE**Temporary aggressive rate-limiting during a confirmed inventory-scalping bot surge**

During a confirmed, active scalping-bot surge against a limited product drop (beyond what the pre-configured Bot Control rules were catching), the e-commerce platform's on-call engineer pushes a temporary, more

aggressive rate-based WAF rule scoped specifically to the product and checkout endpoints for the remainder of the drop window — a manual, incident-time tightening of controls beyond the standing baseline configuration, rolled back automatically via a scheduled rule expiration once the drop window closes.

5.6 The Multi-Source Detection & Remediation Pipeline Pattern

Tying this section together: a mature detection-and-response architecture treats AWS-native services as one of several input sources feeding a central orchestration layer (Tines, in this architecture) rather than building separate, AWS-only response automation disconnected from signals coming from Okta, Prisma Cloud, CrowdStrike, or ArmorCode.

1. Detection sources (GuardDuty, Security Hub, Config, Macie, Okta ThreatInsight, Prisma Cloud alerts, CrowdStrike detections) emit events — natively to EventBridge for AWS sources, via webhook or polling connector for third-party sources.
2. EventBridge rules forward matching AWS events to a Tines webhook via API destination; third-party tools push or are polled directly into Tines using their own native connectors.
3. Tines enrichment stories add context before any decision is made — resource owner lookup, tagging/criticality lookup, asset/tenant mapping, prior-finding history — so the same raw signal that would be ambiguous in isolation becomes a confidently triageable case.
4. Tines decision logic routes based on confidence and blast radius: high-confidence/low-risk triggers automated remediation; ambiguous or high-blast-radius cases route to a human approval step in Slack before any action fires.
5. Every action and decision is logged back to a case management or ticketing system automatically, and a feedback loop (false-positive tagging) feeds back into tuning the detection rules and Tines decision logic over time.

5.7 Respond Function — Summary Table

Service	Primary Role	Pairs With / Alternatives
EventBridge	Event routing backbone for automated response	Tines (API destinations), Lambda, Step Functions
Lambda	Automated remediation execution	SSM Automation documents
Incident Manager	Incident coordination & on-call	PagerDuty, Opsgenie
Step Functions	Multi-step response orchestration with approval gates	Tines orchestration
WAF (active IP sets)	Real-time blocking during active incidents	Cloudflare WAF
Network Firewall (rule updates)	Centralized egress containment	Palo Alto/Fortinet appliances

6. RECOVER

Recover is frequently treated as a pure infrastructure/SRE concern separate from security, which is a mistake specifically in the ransomware and destructive-attack threat model — recovery controls are themselves security controls, and a security architecture review that stops at Protect/Detect/Respond without validating Recover capability is reviewing only half the actual risk.

6.1 AWS Backup

AWS Backup is the centralized, policy-driven backup orchestration service spanning EBS, RDS/Aurora, DynamoDB, EFS, FSx, S3, and EC2 — replacing what would otherwise be a patchwork of per-service native backup configuration managed inconsistently across teams.

Mechanism

- Backup plans define schedule, lifecycle, and target vault, assigned via tags or direct resource selection — and assigned org-wide via Backup Policies so individual account teams cannot accidentally ship a resource with no backup coverage.
- **Vault Lock:** the control that actually matters for ransomware resilience — applying a Vault Lock in compliance mode makes the backup vault's retention policy immutable, including against the AWS account root user and even against AWS itself once locked past the cooling-off period.
- Cross-account and cross-region copy: backup plans can automatically copy backups to a separate, logically isolated account and/or region — this is the control that defeats the most realistic ransomware scenario, where an attacker who has compromised broad IAM access in the primary account still cannot reach backups in an account they were never granted access to.
- Restore testing: AWS Backup supports scheduled, automated restore testing — actually validating restorability on a schedule rather than discovering during an actual disaster that backups have been silently failing for months.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Vault Lock compliance mode satisfying a regulatory backup-immutability requirement

A bank's regulator requires that backups of core transaction data be demonstrably immutable for a defined retention period as part of operational resilience requirements. AWS Backup Vault Lock, configured in compliance mode with the retention period matching the regulatory minimum, provides exactly this guarantee — and during the bank's next regulatory exam, the examiner's specific question about whether backup data could be altered or deleted by a privileged insider is answered definitively by the Vault Lock configuration itself, rather than by a policy document describing intended practice.

SAAS / MULTI-TENANT PLATFORM

Cross-account backup copy defeating a ransomware scenario that compromised the production payer account

A SaaS platform's tabletop ransomware exercise specifically models a scenario where the attacker gains broad administrative access to the production AWS account itself, including IAM admin rights — the exercise confirms that because backups are automatically copied via AWS Backup to a separate, dedicated backup account that production account roles can write to but never delete from, even this worst-case compromise scenario leaves the backup copies untouched and the platform recoverable, validating the isolation architecture rather than just assuming it would hold.

E-COMMERCE

Automated restore testing catching a silently broken backup before it was actually needed

An e-commerce platform's scheduled AWS Backup restore testing, run monthly against the product-catalog database, catches that backups taken over the preceding three weeks were technically completing successfully but restoring to a corrupted state due to an unrelated database engine configuration change — discovered during routine automated testing rather than during an actual outage, giving the team time to fix the underlying issue and re-validate before any real recovery was ever needed.

Real-world implementation note

The architecture pattern that matters most here: a dedicated backup account, separate from both the workload accounts and the Log Archive/Audit account, that workload account roles can write backups TO but cannot delete FROM — enforced via the vault's resource-based access policy plus Vault Lock.

Alternatives

Veeam, Druva, and Rubrik are the common third-party alternatives, generally chosen when an organization needs unified backup management spanning AWS, Azure, GCP, and on-prem under a single policy and reporting console, or needs more advanced ransomware-specific anomaly detection on backup data itself than AWS Backup natively provides.

6.2 S3 Versioning & Object Lock — Recovery Angle

Introduced under Protect for its data-protection role; the recovery-specific framing is worth restating separately because it's the control most directly relevant to ransomware and accidental/malicious deletion recovery for object storage specifically.

- Versioning alone protects against accidental overwrite/delete by preserving prior versions, but a sufficiently privileged identity can still permanently delete all versions — versioning is necessary but not sufficient for ransomware resilience on its own.
- Object Lock in compliance mode, applied with a defined retention period on the buckets holding the most critical data, is what closes that gap — combined with MFA Delete as an additional layer.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

MFA Delete combined with Object Lock on regulatory archive buckets

A bank's regulatory-archive S3 buckets require both Object Lock compliance mode and MFA Delete configured together, specifically so that even the narrow set of operations Object Lock alone doesn't fully cover (certain bucket-level configuration changes) still require a physical MFA device in the possession of an authorized administrator — a layered control the bank's auditors specifically tested by attempting (in a controlled exercise) to delete a locked archive object and confirming the operation failed even with otherwise-valid administrative credentials.

SAAS / MULTI-TENANT PLATFORM

Object Lock specifically on customer data-export archives following a near-miss accidental deletion

After an engineer's automation script had a bug that nearly deleted an entire month of customer data-export archives (caught and reversed using versioning before any data was actually lost), a SaaS platform adds Object Lock in compliance mode specifically to the export-archive bucket with a 35-day retention window matching their data-retention policy — ensuring that even a future, more severe version of the same kind of automation bug cannot result in actual permanent data loss within the policy's retention window.

E-COMMERCE

Versioning protecting against an accidental bulk-delete during a catalog migration

During a large product-catalog data migration, a script intended to delete only deprecated test records instead matched and deleted a broader set of live catalog images due to a filter logic error. Because the

bucket had versioning enabled, every deleted object's prior version remained recoverable, and the team restored the affected objects within the hour — a scenario that, without versioning, would have required restoring from the previous night's full backup and losing any same-day catalog updates.

6.3 AWS Elastic Disaster Recovery (DRS)

DRS provides continuous, block-level replication of on-prem or cloud servers into a low-cost staging area in a target AWS region, with the ability to launch fully provisioned, recovery-ready instances within minutes of a declared disaster.

- **Mechanism:** a lightweight agent replicates block-level changes continuously to a staging subnet in the target region/account, where data is held cheaply until a recovery is actually launched, at which point DRS automatically provisions right-sized EC2 instances from the replicated data.
- **Relationship to KMS Multi-Region Keys:** any DRS-replicated data encrypted at the source using a KMS CMK needs that key (or a multi-region replica of it) available in the target recovery region — a DR plan that hasn't accounted for key availability in the failover region will replicate unreadable data.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Sub-hour RTO for a regulator-mandated core-banking failover capability

A bank's regulator mandates a maximum recovery time objective of under one hour for core-banking transaction processing. DRS's continuous block-level replication into a staging area in a separate region, combined with a pre-tested launch runbook, lets the bank demonstrate during the mandated annual DR test that a full regional failover — from declared disaster to processing live transactions in the recovery region — completes within the regulatory window, a target that a traditional nightly-snapshot-and-rebuild approach could not realistically meet.

SAAS / MULTI-TENANT PLATFORM

DRS as the fallback for a legacy monolith that predates the platform's multi-region application architecture

A SaaS platform's newer microservices are built with native multi-region active-active resilience, but a legacy billing monolith inherited from an early acquisition isn't yet re-architected for that pattern. Rather than delaying disaster-recovery coverage until the re-architecture project completes (a multi-quarter effort), the platform uses DRS specifically for that legacy monolith as an interim server-level DR mechanism, ensuring the weakest link in the architecture isn't also the one with no recovery plan at all.

E-COMMERCE

Validating recovery-region key availability during a DR game day, catching a gap before it mattered

During a scheduled DR game-day exercise, an e-commerce company's team discovers that a KMS CMK protecting a specific subset of customer data was a single-region key, not a multi-region key — meaning the DRS-replicated data in the recovery region, while present, would have been undecryptable during an actual failover. The gap is caught and remediated during the planned exercise specifically because the team tests the full recovery process end-to-end rather than only validating that data replication itself was occurring.

6.4 Config & CloudFormation — Recovery Angle

Both services were introduced earlier in this document for governance and drift-detection roles; both also play a direct recovery role worth calling out.

- **Config remediation as recovery:** a Config rule's remediation action isn't only useful for closing a misconfiguration proactively — the same mechanism is how an environment recovers configuration state after an incident has altered it, without waiting for a human to manually identify and reverse every change an attacker made.

- **CloudFormation (and Terraform) as infrastructure recovery:** for any environment built and managed as infrastructure-as-code, the actual fastest and most reliable recovery path for a compromised or destroyed environment is frequently tearing down the affected stack and redeploying from the last known-good IaC state and a clean backup, rather than attempting to manually identify and reverse every change within a live, potentially still-compromised environment.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Automated reversion of an attacker-modified security group during active incident containment

During an active incident where an attacker briefly gained access sufficient to modify a security group on a sensitive internal service, opening an unintended inbound path, a Config rule monitoring that specific security group's expected baseline configuration flags the deviation and triggers an automated remediation reverting it to the documented known-good state within minutes of the change — closing the unauthorized access path automatically as part of the broader incident response, without waiting for a human to manually identify exactly what the attacker had changed.

SAAS / MULTI-TENANT PLATFORM

Full environment rebuild from IaC following a suspected supply-chain compromise of a build dependency

Following a suspected compromise of a build-time dependency with uncertain scope of impact across the build pipeline, a SaaS platform's security team makes the call to fully rebuild the affected service's infrastructure from its Terraform definitions in a fresh AWS account, rather than attempting to audit and clean the existing, potentially-compromised environment line by line — a decision only possible because the infrastructure was fully defined in version-controlled IaC with no manually-configured drift, illustrating why IaC coverage is treated as a security control rather than purely a DevOps practice.

E-COMMERCE

CloudFormation stack redeployment restoring the checkout service after a botched manual hotfix

An engineer's manual, undocumented hotfix applied directly in the console during a production incident introduced a subtle misconfiguration that wasn't caught until days later. Rather than trying to manually identify and reverse the specific undocumented change, the team redeployes the affected CloudFormation stack from the last known-good template version in source control, restoring the service to a known, version-controlled state in minutes — the same mechanism that exists for true compromise recovery turns out to also be the fastest path for recovering from ordinary operational mistakes.

6.5 Multi-Account Recovery Pattern — Summary

Pulling the Recover function together into the architecture pattern that should actually be reviewed and tested, not just documented:

- A dedicated, isolated backup/vault account holds cross-account-copied backups with Vault Lock compliance mode active; workload account roles can write but not delete.
- Critical infrastructure is defined in IaC (CloudFormation or Terraform) version-controlled outside the AWS environment itself, so a full environment rebuild does not depend on any state stored inside the environment being rebuilt.
- KMS keys protecting any data with a defined recovery requirement are multi-region keys (or have an equivalent key-availability plan) so replicated/restored data in a recovery region is actually decryptable.
- Restore procedures are tested on a defined cadence, with results tracked as a governance metric, not assumed to work because they were configured correctly once.

- The recovery plan explicitly accounts for the scenario where the primary management/payer account itself is compromised — meaning at minimum the backup account and recovery procedures cannot depend entirely on access that originates from the compromised account.

6.6 Recover Function — Summary Table

Service	Primary Role	Pairs With / Alternatives
AWS Backup	Centralized backup orchestration, Vault Lock	Veeam, Druva, Rubrik
S3 Versioning / Object Lock	Object-level immutability and recovery	MFA Delete, Macie
AWS Elastic Disaster Recovery	Continuous replication, fast server-level failover	Multi-AZ/multi-region app architecture
Config remediation	Automated configuration state recovery	Lambda, SSM Automation
CloudFormation / Terraform	Infrastructure rebuild from version-controlled IaC	Terragrunt, AFT

Appendix A — Full Service Cross-Reference Matrix

Services that appear under multiple CSF functions are listed once per relevant function, consistent with their treatment in the body of this document.

Service	CSF Function(s)	Key Alternative / Complement
AWS Organizations	Govern	—
AWS Control Tower	Govern	Terraform + custom landing zone
AWS Config	Govern, Identify, Recover	Wiz, Prisma Cloud
IAM Access Analyzer	Govern, Identify	CIEM platforms
AWS Artifact	Govern	—
Security Hub	Identify, Detect	Wiz, Prisma Cloud, SIEM
Amazon Inspector	Identify	Tenable, Qualys, Snyc
Amazon Macie	Identify, Detect	DSPM (Wiz DSPM, BigID)
Trusted Advisor	Identify	Config, Security Hub
Resource Explorer	Identify	Config aggregator, CSPM graph
IAM	Protect	CIEM tools
IAM Identity Center	Protect	Okta, Entra ID (as source IdP)
AWS KMS	Protect	CloudHSM, XKS
Secrets Manager	Protect	Parameter Store, Vault
Parameter Store	Protect	Secrets Manager
AWS WAF	Protect, Respond	Cloudflare WAF
AWS Shield	Protect	Cloudflare DDoS
Network Firewall	Protect, Respond	Palo Alto, Fortinet, Check Point
Security Groups / NACLs	Protect	—
VPC Endpoints / PrivateLink	Protect	VPC Peering, Transit Gateway
Certificate Manager	Protect	Private CA, cert-manager
Amazon Cognito	Protect	Auth0, WorkOS
AWS CloudHSM	Protect	KMS shared HSM
S3 security controls	Protect, Recover	Macie, Object Lock
Systems Manager (Session/Patch Mgr)	Protect	Teleport, StrongDM
Amazon CloudFront	Protect	Cloudflare, Fastly
Amazon Route 53	Protect, Detect	Cloudflare DNS, Infoblox
AWS Firewall Manager	Protect, Govern	Wiz/Prisma policy enforcement, OPA/Sentinel

Service	CSF Function(s)	Key Alternative / Complement
Amazon GuardDuty	Detect	CrowdStrike, SentinelOne
AWS CloudTrail	Detect	CloudTrail Lake, Splunk, Sentinel
Amazon CloudWatch	Detect	Datadog, SIEM
Amazon Detective	Detect	Velociraptor, DFIR platforms
VPC Flow Logs	Detect	Network Firewall
Amazon EventBridge	Respond	Tines, SOAR platforms
AWS Lambda (remediation)	Respond	SSM Automation
Incident Manager	Respond	PagerDuty, Opsgenie
Step Functions	Respond	Tines orchestration
AWS Backup	Recover	Veeam, Druva, Rubrik
AWS Elastic Disaster Recovery	Recover	Multi-region app architecture
CloudFormation	Recover	Terraform, Terragrunt

Appendix B — Architecture Principles Referenced Throughout

- **1. The management/payer account runs no workloads.** Its sole function is org governance, billing, and break-glass access.
- **2. No long-lived credentials for humans.** Workforce access is federated through Okta and IAM Identity Center; workload identity uses short-lived STS credentials (IRSA, instance profiles, OIDC federation for CI/CD).
- **3. Detective controls are enabled org-wide by default at account creation,** not opt-in per team — GuardDuty, Security Hub, Config, and CloudTrail organization trail are baseline, not optional hardening.
- **4. Every Protect control is evaluated against tenant-isolation failure, not just external-attacker failure.** ABAC session tags, per-tenant KMS keys where justified, and tenant claims validated end-to-end from JWT issuance through IAM enforcement are the mechanisms that make this real rather than aspirational.
- **5. Detection signal from every source — AWS-native and third-party — converges on one orchestration layer.** Findings that don't reach a common pipeline don't get a consistent response, regardless of how good the originating tool is.
- **6. Recovery capability assumes the primary account or region is the thing that failed.** Backups, IaC state, and recovery procedures cannot depend entirely on access or state that originates from the environment being recovered.

— End of Document —